PROMETEO



Diseño e implementación de una arquitectura de red segura basada en el modelo Zero Trust para la protección de infraestructuras críticas.

Grado Superior en Administración de Sistemas informáticos en Red.

Modalidad Online

Alumno: Francisco de Asís Sierra de la Rosa

Tutor TFG: Dña. Susana Roldán Parra

PROMETEO

DEDICATORIA (OPCIONAL)

ÍNDICE

PORTADA 1

DEDICATORIA 2

ÍNDICE 3

1. Abstract 4

2. Justificación del proyecto 6

3. Introducción 10

4. Objetivos 13

5. Descripción 17

6. Diseños 23

7. Tecnología 24

8. Metodología 27

9. Desarrollo de la solución 31

10. Trabajos futuros 60

11. Conclusiones 62

12. Lecciones aprendidas 63

13. Referencias 64

ABSTRACT

Las redes tradicionales planas se basan en la confianza implícita, de modo que un atacante que supera el perímetro puede moverse lateralmente hasta alcanzar los activos críticos. Este proyecto diseña, despliega y valida una red corporativa segmentada basada en el modelo Zero Trust (NIST SP 800-207), orientada a la protección de infraestructuras críticas. La arquitectura divide la red en zonas de confianza mediante VLANs gobernadas por un cortafuegos que actúa como punto de aplicación de políticas, aplica microsegmentación con denegación por defecto y reglas explícitas por flujo, ofrece acceso remoto seguro a través de una VPN restringida a un segmento controlado, e incorpora detección de intrusiones y registro para la verificación continua. La solución se implementa en un laboratorio virtualizado y se evalúa mediante pruebas de aislamiento controladas que comparan su postura de seguridad con la de una red plana equivalente. Los resultados mostrarán que la segmentación Zero Trust reduce significativamente la superficie de ataque y contiene el movimiento lateral hacia la zona crítica, demostrando que el modelo puede implementarse de forma realista con herramientas de administración de sistemas y redes de código abierto.

Palabras clave: Zero Trust, segmentación de red, microsegmentación, NIST SP 800-207, infraestructura crítica, cortafuegos, VPN, movimiento lateral.

Traditional flat networks rely on implicit trust, so an attacker who breaches the perimeter can move laterally until reaching critical assets. This project designs, deploys and validates a segmented enterprise network based on the Zero Trust model (NIST SP 800-207), aimed at protecting critical infrastructure. The architecture divides the network into trust zones through VLANs governed by a firewall acting as the policy enforcement point, applies default-deny microsegmentation with explicit per-flow rules, provides secure remote access over a VPN restricted to a controlled segment, and adds intrusion detection and logging for continuous verification. The solution is implemented in a virtualized laboratory and evaluated through controlled isolation tests

that compare its security posture against an equivalent flat network. The results are expected to show that Zero Trust segmentation significantly reduces the attack surface and contains lateral movement toward the critical zone, demonstrating that the model can be realistically implemented with open-source systems- and network-administration tools.

Keywords: Zero Trust, network segmentation, microsegmentation, NIST SP 800-207, critical infrastructure, firewall, VPN, lateral movement.

JUSTIFICACIÓN DEL PROYECTO

Motivación principal

Durante años, la seguridad de las redes corporativas se ha basado en un modelo perimetral: una frontera fuerte (el cortafuegos) y confianza implícita en todo lo que quedaba dentro. Ese modelo ha quedado desfasado. La adopción del teletrabajo, la nube y los dispositivos móviles ha difuminado el perímetro, y los incidentes recientes demuestran que, una vez un atacante entra, el movimiento lateral dentro de una red plana le permite alcanzar los activos más sensibles con poca resistencia (táctica TA0008 en MITRE ATT&CK). De hecho, según el Data Breach Investigations Report de Verizon, el 32 % de todas las brechas analizadas en 2024 implicaron ransomware u otra técnica de extorsión (Verizon, 2024), ataques que se apoyan precisamente en esa propagación interna para maximizar su impacto."

Frente a esto surge el modelo Zero Trust ("nunca confíes, verifica siempre"), formalizado por el NIST en la SP 800-207 (Rose et al., 2020) y convertido en mandato para la administración federal estadounidense (Executive Order 14028, 2021; OMB M-22-09, 2022) y en línea de trabajo de la OTAN y la UE. En España, el Esquema Nacional de Seguridad (RD 311/2022) empuja en la misma dirección: segmentación, mínimo privilegio y verificación continua.

La motivación del proyecto es doble: técnica, demostrar que estos principios, hoy asociados a productos comerciales caros, pueden implementarse con herramientas de administración de sistemas y redes de código abierto, al alcance de organizaciones medianas; y profesional, alinear el trabajo con el ámbito de la ciberseguridad aplicada a la protección de infraestructuras y a la seguridad nacional, donde la soberanía sobre la propia infraestructura es un requisito, no una opción.

Estado de la cuestión

Zero Trust no es un producto, sino un modelo. El término lo acuñó John Kindervag en Forrester (2010), y el mercado lo ha materializado en varias familias de soluciones:

ZTNA / SASE en la nube (Zscaler Private Access, Palo Alto Prisma Access, Cloudflare Zero Trust): sustituyen la VPN tradicional por acceso por aplicación, gestionado desde la nube del proveedor.

Microsegmentación basada en agente (Illumio, Cisco Secure Workload): controlan el tráfico este-oeste instalando agentes en cada host.

Segmentación de red on-premise con cortafuegos y VLANs (pfSense/OPNsense, y proyectos como OpenZiti o WireGuard para el acceso): aplican los principios a nivel de red, sin dependencia de un proveedor externo.

Existen, por tanto, soluciones maduras, pero comparten dos limitaciones para el escenario de este proyecto: coste (licenciamiento por usuario/host) y dependencia de la nube del fabricante, problemática en entornos aislados, industriales (OT) o con requisitos de soberanía del dato. La aportación de este trabajo es demostrar y medir la eficacia de la tercera vía -segmentación open-source autoalojada - en un caso de infraestructura crítica.

Público objetivo

PYMEs y organizaciones medianas que necesitan elevar su postura de seguridad sin asumir el coste de suites comerciales.

Organismos públicos y entornos sujetos al ENS, que requieren segmentación y control sobre su propia infraestructura.

Entornos industriales/OT y sistemas críticos aislados, donde las soluciones cloud no encajan.

Valor formativo: laboratorio reproducible para entender Zero Trust a nivel de red.

Comparativa

Criterio	ZTNA/SASE cloud (Zscaler, Prisma, Cloudflare)	Microsegmentación por agente (Illumio, Cisco)	Segmentación on-premise open-source (este proyecto)
Coste	Alto (licencia por usuario)	Alto (licencia por host)	Bajo (software libre)
Soberanía de dato	Baja (tráfico por nube del proveedor)	Media	Alta (todo autoalojado)
Entornos aislados / OT	Mala (requiere conectividad cloud)	Media	Buena (funciona air-gapped)
Complejidad de despliegue	Baja (gestionado)	Media-alta (agentes)	Media (configuración de red)
Escalabilidad	Muy alta	Alta	Media (adecuada a org. mediana)
Transparencia / auditabilidad	Baja (caja negra)	Baja-media	Alta (código abierto)
Encaje en Asir	Bajo (poco que administrar)	Medio	Alto (redes + SAD)

Tabla 1: Comparativa

Lectura de la comparativa: Las soluciones comerciales ganan en escalabilidad y facilidad de gestión, y son la opción correcta para grandes corporaciones. Pero para el público objetivo definido -organizaciones medianas, entornos con soberanía del dato y sistemas críticos aislados- penalizan en coste, dependencia externa e imposibilidad de operar sin nube. La segmentación on-premise con herramientas open-source ofrece el mejor equilibrio para ese contexto: coste asumible, control total

de la infraestructura, funcionamiento en entornos aislados y total transparencia. Además, es la única de las tres que ejercita de forma directa las competencias del ciclo ASIR (administración de redes y seguridad). Por eso es la vía elegida.

INTRODUCCIÓN

El presente proyecto aborda el diseño, la implementación en laboratorio y la validación de una arquitectura de red segura basada en el modelo Zero Trust. Frente al enfoque perimetral tradicional en el que todo lo que está dentro de la red se considera de confianza, el proyecto parte del principio "nunca confíes, verifica siempre" y lo materializa en una red segmentada donde ningún flujo entre zonas se permite por defecto. El escenario simula una organización con una zona crítica que debe quedar protegida frente al movimiento lateral, incluyendo el acceso remoto seguro de usuarios externos.

Principales funciones

El sistema resultante cumple las siguientes funciones:

Segmentar la red en zonas de confianza diferenciadas (usuarios, servidores, DMZ, gestión y zona crítica) mediante VLANs.

Controlar el tráfico con un cortafuegos que actúa como punto central de aplicación de políticas, con denegación por defecto y reglas explícitas por flujo (mínimo privilegio).

Proporcionar acceso remoto seguro mediante una VPN cifrada que da acceso únicamente a un segmento acotado, no a toda la red.

Detectar y registrar el tráfico y los intentos de acceso no autorizados (detección de intrusiones y registro centralizado) para la verificación continua.

Aislar y proteger los activos de la zona crítica, conteniendo la propagación de un atacante que hubiera comprometido otra zona.

Validar la eficacia de la solución mediante pruebas controladas y una comparativa medible frente a una red plana equivalente.

Problemas que resuelve:

Problema	Cómo lo resuelve el proyecto
Confianza implícita en la red interna, movimiento lateral	Microsegmentación con denegación por defecto entre zonas
Perímetro difuso (teletrabajo, nube) y VPN de acceso total	VPN restringida a un único segmento controlado
Falta de visibilidad del tráfico interno (este-oeste)	Detección de intrusiones y registro centralizado
Exposición de activos críticos	Zona crítica aislada tras el punto de aplicación de políticas
Coste y dependencia de soluciones comerciales en la nube	Herramientas de código abierto autoalojadas (soberanía del dato)
Dificultad para cumplir marcos como el ENS sin segmentación	Diseño alineado con la segmentación y el mínimo privilegio que exige el ENS

Tabla 2: Resolución de problemas

Principales requisitos que debe cumplir

Requisitos funcionales (RF)

RF1 - La red debe estar segmentada en, al menos, cinco zonas de confianza mediante VLANs.

RF2 - El cortafuegos debe aplicar una política de denegación por defecto y permitir el tráfico solo por reglas explícitas.

RF3 - Debe existir acceso remoto cifrado por VPN limitado a un segmento restringido.

RF4 - El sistema debe detectar y registrar los intentos de acceso no autorizados entre zonas.

RF5 - La zona crítica debe quedar inaccesible desde el resto de zonas salvo los flujos expresamente autorizados.

RF6 - Debe poder validarse el aislamiento mediante pruebas reproducibles (escaneos/barridos) y compararse con una red plana.

Requisitos no funcionales (RNF)

RNF1 - Se emplearán herramientas de código abierto (coste asumible y soberanía sobre la infraestructura).

RNF2 - El entorno debe ser reproducible en un laboratorio virtualizado.

RNF3 - El diseño debe alinearse con los principios de NIST SP 800-207 y el ENS.

RNF4 - La solución debe funcionar con los recursos de hardware disponibles (memoria y CPU limitadas).

RNF5 - Las comunicaciones sensibles deben ir cifradas y las credenciales de administración deben ser robustas.

RNF6 - La arquitectura debe ser mantenible y razonablemente escalable a más zonas o servicios.

OBJETIVOS

Objetivo general: Demostrar que una arquitectura de red segmentada según el modelo Zero Trust reduce la superficie de ataque y contiene el movimiento lateral frente a una red plana tradicional, empleando herramientas de código abierto.

Objetivos específicos:

OE1 (> R01): Segmentar la red en zonas de confianza mediante VLANs.

OE2 (> R02): Aplicar microsegmentación con denegación por defecto y reglas de mínimo privilegio.

OE3 (> R03): Proporcionar acceso remoto seguro y acotado mediante VPN cifrada.

OE4 (> R04): Detectar y registrar los intentos de acceso no autorizados.

OE5 (> R05): Aislar y proteger la zona crítica frente al movimiento lateral.

OE6 (> R06): Validar la eficacia de la solución con pruebas medibles y comparativa con red plana.

RFTP inicial

R01 - La red debe estar dividida en zonas separadas para que lo que ocurra en una no afecte a las demás.

R01F01 - Definir y crear las zonas de confianza mediante segmentación por VLANs.

R01F01T01 - Diseñar el direccionamiento IP y asignar una VLAN a cada zona (usuarios, servidores, DMZ, gestión, crítica).

R01F01T01P01 - Comprobar en la tabla de VLANs/interfaces del cortafuegos que cada zona tiene su rango y VLAN.

R01F01T02 - Configurar el etiquetado 802.1Q en las interfaces del cortafuegos y del conmutador.

R01F01T02P01 - Verificar que un host de cada zona obtiene dirección de su rango (ipconfig/ip a).

R01F02 - Dotar a cada zona de conectividad interna funcional.

R01F02T01 - Configurar el enrutamiento del cortafuegos hacia cada VLAN.

R01F02T01P01 - Comprobar que un host alcanza la puerta de enlace de su VLAN (ping al gateway).

R02 - Nada debe poder comunicarse entre zonas salvo lo que se autorice expresamente.

R02F01 - Aplicar una política de denegación por defecto en el cortafuegos.

R02F01T01 - Establecer la regla final de bloqueo (deny all) y retirar reglas permisivas por defecto.

R02F01T01P01 - Desde una zona, intentar alcanzar otra sin regla y comprobar que se bloquea.

R02F02 - Permitir solo los flujos necesarios con reglas explícitas (mínimo privilegio).

R02F02T01 - Documentar la matriz de flujos permitidos (origen, destino, puerto, servicio).

R02F02T01P01 - Revisar que cada regla del cortafuegos se corresponde con una entrada de la matriz.

R02F02T02 - Crear las reglas de los flujos autorizados (p. ej., usuarios > web en DMZ por 443).

R02F02T02P01 - Comprobar que el flujo autorizado funciona y el resto sigue bloqueado.

R03 - Los usuarios externos deben poder conectarse de forma segura solo a la parte que les corresponde.

R03F01 - Desplegar un servicio de VPN cifrada en el cortafuegos.

R03F01T01 - Configurar el servidor VPN y generar las claves/credenciales de un cliente.

R03F01T01P01 - Establecer la conexión desde un cliente externo y verificar el túnel cifrado.

R03F02 - Restringir el acceso del cliente VPN a un único segmento.

R03F02T01 - Crear reglas que limiten el tráfico del cliente VPN al segmento autorizado.

R03F02T01P01 - Desde el cliente VPN, comprobar acceso al recurso permitido y bloqueo hacia la zona crítica.

R04 - El sistema debe avisar y dejar registro cuando alguien intente algo no permitido.

R04F01 - Desplegar detección de intrusiones en el punto de control.

R04F01T01 - Activar y configurar el IDS con un conjunto de reglas adecuado.

R04F01T01P01 - Lanzar un escaneo de puertos de prueba y comprobar que el IDS lo detecta.

R04F02 - Centralizar el registro de eventos.

R04F02T01 - Configurar el registro del cortafuegos y del IDS y su consulta.

R04F02T01P01 - Localizar en los registros el intento de acceso bloqueado de la prueba anterior.

R05 - La zona crítica debe quedar protegida aunque otra zona sea comprometida.

R05F01 - Aislar la zona crítica del resto de segmentos.

R05F01T01 - Configurar reglas que impidan todo acceso entrante a la zona crítica salvo el flujo mínimo imprescindible.

R05F01T01P01 - Desde cada una de las demás zonas, intentar acceder a la zona crítica y comprobar el bloqueo.

R05F02 - Simular un compromiso y verificar la contención.

R05F02T01 - Desde una zona "comprometida" (usuarios), intentar movimiento lateral hacia la zona crítica.

R05F02T01P01 - Comprobar que el intento no alcanza la zona crítica y queda registrado.

R06 - Se debe poder demostrar que la segmentación protege mejor que una red plana.

R06F01 - Establecer un escenario de referencia (red plana) para comparar.

R06F01T01 - Configurar temporalmente un escenario equivalente sin segmentación.

R06F01T01P01 - Ejecutar el mismo intento de movimiento lateral y comprobar que en la red plana sí alcanza la zona crítica.

R06F02 - Medir y comparar los resultados de ambos escenarios.

R06F02T01 - Ejecutar una batería de pruebas de aislamiento (escaneos/barridos) en ambos escenarios y registrar resultados.

R06F02T01P01 - Elaborar una tabla comparativa con el porcentaje de flujos bloqueados en cada escenario.

DESCRIPCIÓN

Arquitectura de la solución.

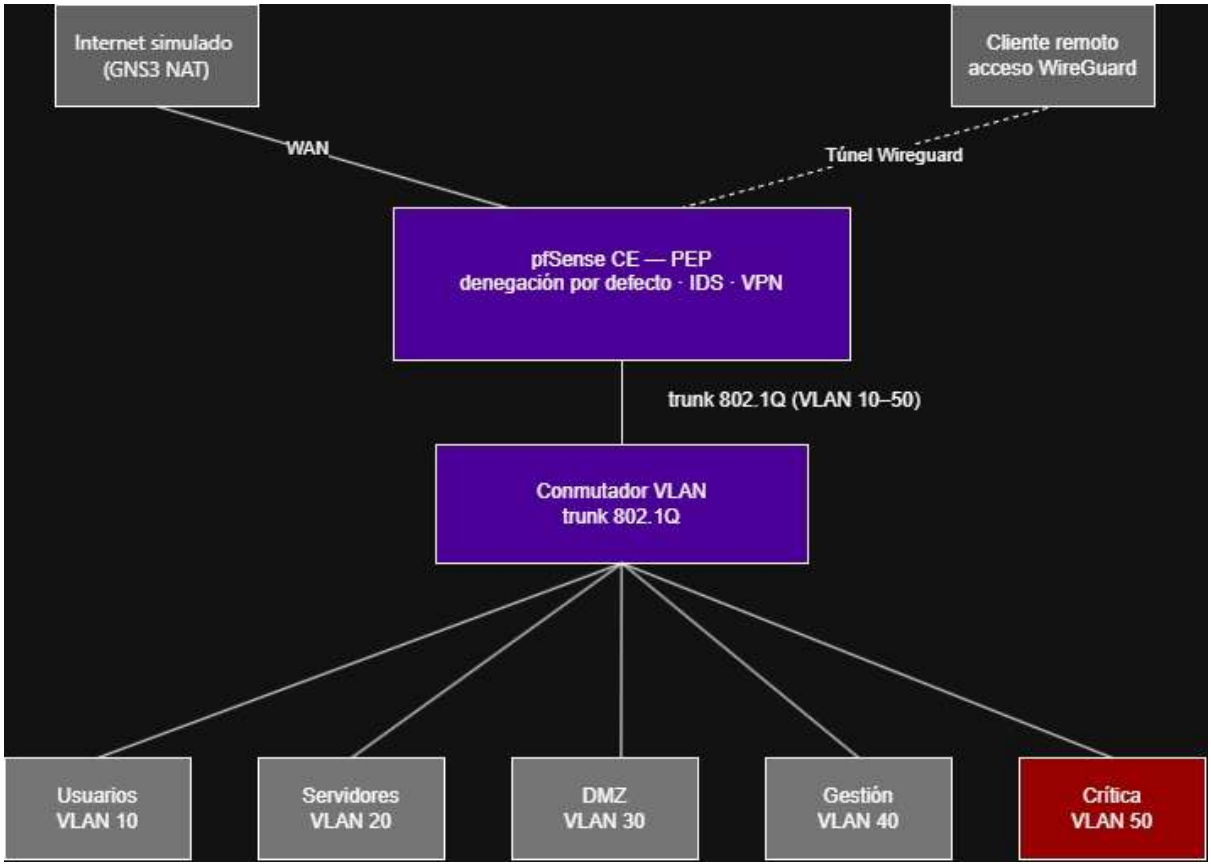


Ilustración 1: Arquitectura de la solución

Leyenda de colores: púrpura = punto de control Zero Trust (pfSense/conmutador) · gris = zonas y entorno · rojo = zona crítica protegida.

La solución se estructura en torno a un cortafuegos pfSense que centraliza el enrutamiento y el control del tráfico entre cinco zonas de confianza, implementadas como VLANs. El cortafuegos actúa como punto de aplicación de políticas (PEP) del modelo Zero Trust: agrupa cada conjunto de activos según su nivel de exposición y criticidad (usuarios, servidores internos, DMZ, gestión y zona crítica) y es el único punto por el que puede circular tráfico entre ellas.

El tráfico entre zonas no está permitido por defecto. Solo los flujos explícitamente autorizados recogidos en la matriz de flujos, atraviesan el cortafuegos, aplicando el principio de mínimo privilegio. El acceso remoto de usuarios externos se realiza mediante una VPN WireGuard que da entrada únicamente a un segmento acotado, nunca a la red completa. El motor Suricata inspecciona el tráfico en el punto de control y registra los intentos de acceso no autorizados, aportando la verificación continua propia del modelo.

La zona crítica (VLAN 50) concentra los activos sensibles y recibe el trato más restrictivo: solo es accesible desde la zona de gestión mediante SSH y carece de salida a internet. De este modo, un atacante que lograse comprometer otra zona no podría alcanzarla, conteniéndose el movimiento lateral. El diseño se apoya en los componentes lógicos de NIST SP 800-207 y en los principios de segmentación y mínimo privilegio que exige el Esquema Nacional de Seguridad.

Matriz de flujos permitidos (todo lo no listado, denegado)

Origen	Destino	Servicio	Acción
Internet	DMZ(Web)	TCP 443	Permitir
Usuarios (10)	DMZ (30)	TCP 443	Permitir
DMZ (30)	Servidores (20)	TCP 5432 (BD/app)	Permitir
Cliente VPN (90)	Servidores (20)	TCP 443 (app)	Permitir
Gestión (40)	Zona crítica (50)	TCP 22 (SSH admin)	Permitir
Gestión (40)	Resto de zonas	TCP 22 / 443	Permitir
Servidores / DMZ	Internet	TCP 443 (updates)	Permitir
Zona crítica (50)	Internet	cualquiera	**Denegar** (aislada)
Cualquier zona > Zona crítica (50)	-	cualquiera	**Denegar** (salvo Gestión)
Regla final	-	cualquiera	Denegar (por defecto)

Tabla 3: Flujos permitidos

Diagrama de casos de uso

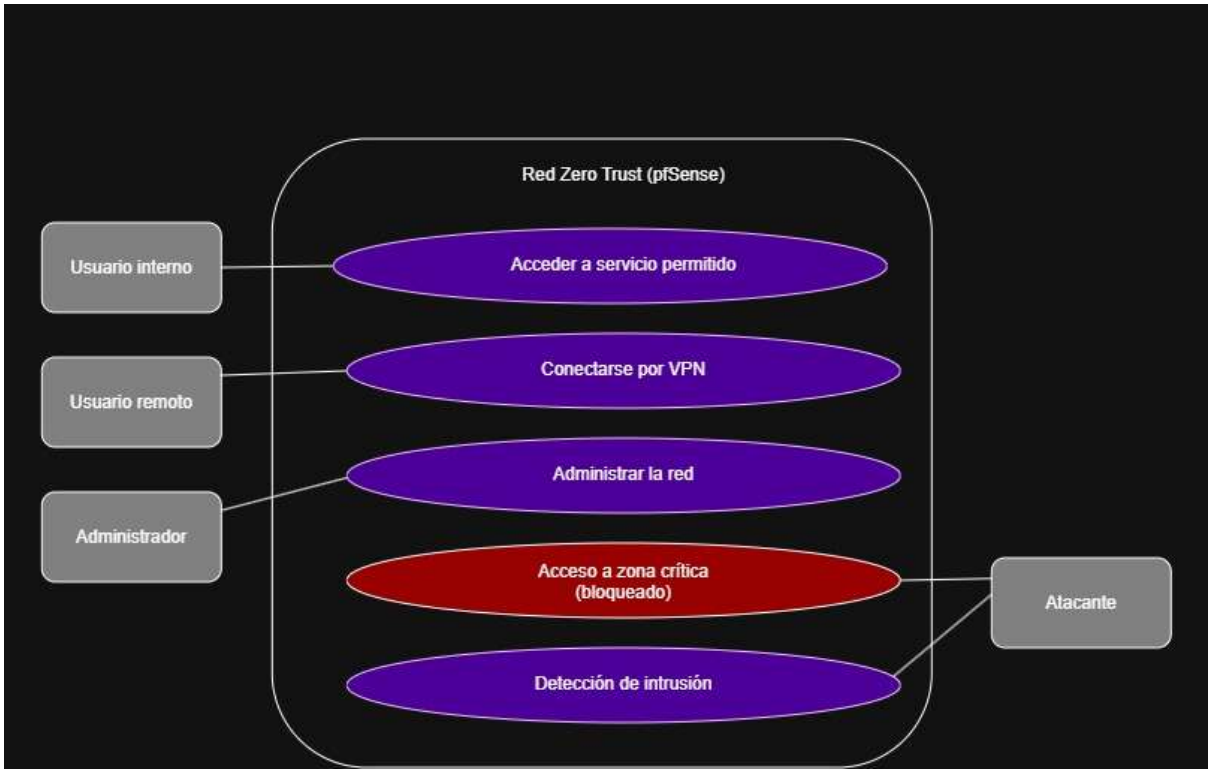


Ilustración 2: Diagrama de casos de uso

CU-01 · Acceder a un servicio permitido

Campo	Valor
Actor	Usuario interno (VLAN 10)
Descripción	Un usuario accede al servicio web publicado en la DMZ
Precondiciones	Host en VLAN 10 con IP válida; regla usuarios > DMZ:443 activa; servicio web operativo
Postcondiciones	Conexión HTTPS establecida; flujo registrado

Datos de entrada	Origen 10.10.10.x, destino 10.10.30.10, puerto TCP 443
Datos de salida	Respuesta del servicio web; entrada en el registro del cortafuegos
Zonas/VLANs implicadas	VLAN 10 (usuarios), VLAN 30 (DMZ)
Reglas del cortafuegos	allow TCP 10.10.10.0/24 > 10.10.30.10:443
Servicios/Interfaces de red	Interfaces VLAN10 y VLAN30 de pfSense; HTTPS

Tabla 4: Acceder a servicio permitido

CU-02 · Conectarse por VPN

Campo	Valor
Actor	Usuario remoto
Descripción	Un usuario externo establece un túnel WireGuard y accede solo al segmento autorizado
Precondiciones	Cliente con clave WireGuard válida; servidor WireGuard activo; regla que acota el túnel
Postcondiciones	Túnel cifrado establecido; acceso concedido solo a VLAN 20; acceso a zona crítica denegado
Datos de entrada	Clave pública del cliente, endpoint WAN:51820, IP de túnel 10.10.90.2
Datos de salida	Interfaz de túnel activa; acceso a 10.10.20.x:443; denegación registrada si intenta VLAN 50
Zonas/VLANs implicadas	Túnel 10.10.90.0/24, VLAN 20

Reglas del cortafuegos	allow 10.10.90.0/24 > 10.10.20.0/24:443; deny 10.10.90.0/24 > 10.10.50.0/24
Servicios/Interfaces de red	WireGuard (UDP 51820), interfaz WAN, interfaz VLAN20

Tabla 5: Conectarse por VPN

CU-03 · Intento de acceso a la zona crítica (bloqueado)

Campo	Valor
Actor	Atacante / host comprometido en VLAN 10
Descripción	Desde una zona comprometida se intenta alcanzar la zona crítica (movimiento lateral); la política lo bloquea
Precondiciones	Host en VLAN 10; política de denegación por defecto activa; sin regla 10>50
Postcondiciones	Conexión rechazada; evento registrado; alerta del IDS
Datos de entrada	Origen 10.10.10.x, destino 10.10.50.x, puerto objetivo
Datos de salida	Paquete descartado (block); entrada en el log; alerta Suricata
Zonas/VLANs implicadas	VLAN 10, VLAN 50
Reglas del cortafuegos	deny (regla final) 10.10.10.0/24 > 10.10.50.0/24
Servicios/Interfaces de red	Interfaces VLAN10/VLAN50; motor Suricata

Tabla 6: Intento de acceso a zona crítica

CU-04 · Detección de intrusión

Campo	Valor
Actor	Atacante (genera) / Administrador (observa)
Descripción	Se ejecuta un escaneo de puertos entre zonas y el IDS lo detecta y registra
Precondiciones	Suricata activo con conjunto de reglas; tráfico de escaneo generado (nmap)
Postcondiciones	Alerta generada y registrada; visible en el panel/logs
Datos de entrada	Tráfico de escaneo (nmap -sS), IP origen/destino
Datos de salida	Alerta Suricata (firma, IP, hora); entrada de log
Zonas/VLANs implicadas	Zona origen y zona destino del escaneo
Reglas del cortafuegos	Conjunto de reglas Suricata (p. ej., ET Open)
Servicios/Interfaces de red	Suricata sobre la interfaz correspondiente; registro

Tabla 7: Detección de intrusión

DISEÑOS

Diagrama de red.

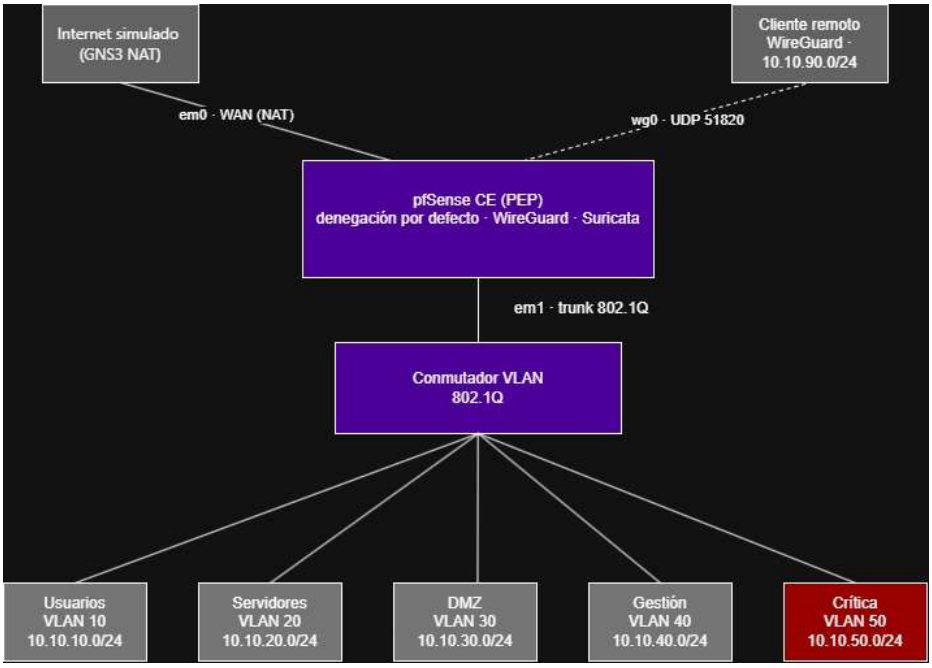


Ilustración 3: Diagrama de red

Interfaz pfSense	Rol	VLAN	Subred	Gateway
em0	WAN (internet)	-	NAT de GNS3	-
em1	Troncal (802.1Q)	-	-	-
em1.10	Usuarios	10	10.10.10.0/24	10.10.10.1
em1.20	Servidores	20	10.10.20.0/24	10.10.20.1
em1.30	DMZ	30	10.10.30.0/24	10.10.30.1
em1.40	Gestión	40	10.10.40.0/24	10.10.40.1
em1.50	Zona crítica	50	10.10.50.0/24	10.10.50.1
wg0	Túnel WireGuard	-	10.10.90.0/24	10.10.90.1

Tabla 8: Redes

TECNOLOGÍA

Plataforma del laboratorio

GNS3 3.0.6

Descripción: emulador de red de código abierto que permite construir topologías reales combinando máquinas virtuales (QEMU/VirtualBox), contenedores Docker y conmutadores virtuales, con soporte de VLANs 802.1Q y enlaces troncales.

Uso en el proyecto: es el entorno donde se monta toda la arquitectura. Aloja el cortafuegos, el conmutador con VLANs y los hosts de cada zona. Se emplean nodos Docker ligeros para los hosts, de modo que la maqueta funcione con los recursos disponibles (RNF4). Da soporte a R01 (segmentación) y RNF2 (reproducibilidad).

Núcleo de red y seguridad

pfSense CE 2.9.0

Descripción: distribución cortafuegos/router de código abierto basada en FreeBSD, ampliable mediante paquetes. Ofrece filtrado por reglas, VLANs, VPN e IDS.

Uso en el proyecto: actúa como punto de aplicación de políticas (PEP) de la arquitectura Zero Trust. Concentra el enrutamiento entre VLANs, la política de denegación por defecto y las reglas de mínimo privilegio (R02, R05), y aloja los servicios de VPN e IDS.

Conmutador con VLANs 802.1Q (switch integrado de GNS3)

Descripción: conmutador virtual que implementa el estándar IEEE 802.1Q de etiquetado de VLANs y puertos de acceso/troncales.

Uso en el proyecto: separa el tráfico de cada zona de confianza y transporta las VLANs hacia el cortafuegos por un enlace troncal (R01F01T02).

Suricata 8.0.6 (paquete de pfSense)

Descripción: motor de detección y prevención de intrusiones (IDS/IPS) de código abierto que analiza el tráfico con conjuntos de reglas.

Uso en el proyecto: detecta y registra actividad sospechosa (escaneos de puertos o intentos de movimiento lateral) en el punto de control, aportando la verificación continua (R04).

Acceso remoto

WireGuard (integrado en pfSense; wireguard-tools 1.0.20260223)

Descripción: protocolo y software de VPN moderno, ligero y cifrado (Curve25519, ChaCha20-Poly1305).

Uso en el proyecto: proporciona el acceso remoto seguro de usuarios externos, restringido por reglas a un único segmento autorizado (R03).

IPsec / IKEv2 - strongSwan 6.1.0 (referencia teórica)

Descripción: conjunto de protocolos de VPN estandarizado, tradicional en entornos corporativos y de administración pública/defensa.

Uso en el proyecto: se estudia en el marco teórico como el estándar de referencia en el ámbito gubernamental y se compara con WireGuard (madurez, interoperabilidad, certificación). No se despliega, se analiza.

Hosts y pruebas

Alpine Linux 3.24.1 (y Debian 13 "trixie" como opción)

Descripción: distribuciones Linux de bajo consumo, ejecutadas como nodos Docker dentro de GNS3.

Uso en el proyecto: representan los equipos de cada zona (usuarios, servidores, DMZ, gestión y zona crítica) sobre los que se comprueban los flujos permitidos y bloqueados.

Nmap 7.99

Descripción: herramienta de exploración de redes y auditoría para descubrimiento de hosts y escaneo de puertos.

Uso en el proyecto: ejecuta las pruebas de aislamiento (barridos y escaneos entre zonas) que validan la segmentación y alimentan la comparativa con la red plana (R06).

Documentación y control de versiones

Git 2.55.0

Descripción: sistema de control de versiones distribuido.

Uso en el proyecto: versiona configuraciones, documentación y evidencias. Los commits se corresponden con las tareas del RFTP para que el historial sea contrastable con el Gantt (Metodología). Incluye el README del proyecto.

diagrams.net (draw.io) 31.4.5

Descripción: herramienta de diagramación de código abierto.

Uso en el proyecto: elabora el diagrama de arquitectura y el diagrama de red exigidos en la Descripción.

GanttProject 3.2

Descripción: software libre de planificación de proyectos con diagramas de Gantt (alternativa a Microsoft Project).

Uso en el proyecto: genera las dos planificaciones (estimada y real) y el diagrama de Gantt de la Metodología.

METODOLOGÍA

Metodología usada

La metodología seguida es iterativa e incremental. El proyecto se divide en incrementos que se corresponden con los requisitos del RFTP (R01–R06), y cada incremento sigue el ciclo construir > configurar > probar > documentar: cada tarea (T) termina en una prueba (P), de modo que ningún requisito se da por cerrado hasta validarse. Se elige este enfoque, frente a un modelo en cascada puro, porque permite obtener capacidades funcionales y verificables desde etapas tempranas, detectar problemas de configuración antes de que se propaguen y encajar de forma natural con las dos entregas parciales de seguimiento exigidas. El avance se controla con Git: cada tarea del RFTP se corresponde con uno o varios commits, lo que hace el historial contrastable con la planificación, el Gantt y los casos de uso.

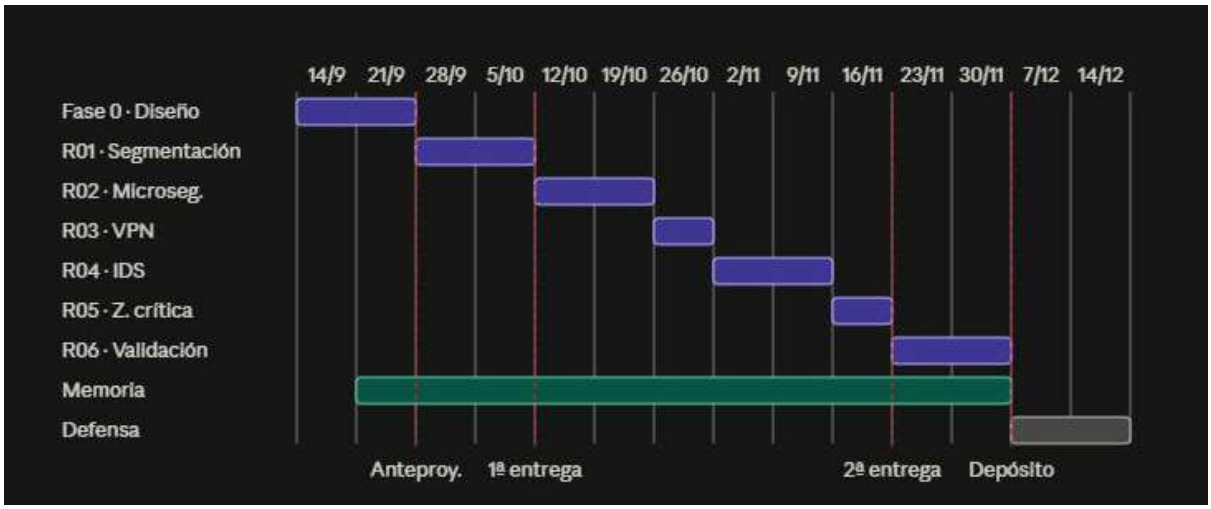


Ilustración 4: Diagrama de Gantt

Planificación inicial (estimada, en horas)

Fase	Parte / RFTP	Horas estimadas
Fase 0	Investigación, marco teórico y diseño	28
Fase 1	R01 - Segmentación (GNS3, pfSense, VLANs, troncal)	24
Fase 2	R02 - Microsegmentación (denegación por defecto + reglas)	20
Fase 3	R03 - Acceso remoto VPN (WireGuard)	16
Fase 4	R04 - Detección de intrusiones y registro (Suricata)	20
Fase 5	R05 - Aislamiento y contención de la zona crítica	16
Fase 6	R06 - Validación y comparativa con red plana	20
Fase 7	Redacción de la memoria	42
Fase 8	Preparación de la defensa	12
Total		**198**

Tabla 9: Planificación inicial

Planificación final y desviaciones

Fase / RFTP	Horas estimadas	Horas reales	Desviación
Fase 0 - Diseño	28	30	2
R01 - Segmentación	24	27	3
R02 - Microsegmentación	20	18	-2
R03 - VPN	16	15	-1
R04 - IDS	20	25	5
R05 - Zona crítica	16	15	-1
R06 - Validación	20	20	0
Memoria	42	48	6
Defensa	12	11	-1
Total	**198**	209	11

Tabla 10: Planificación final y desviaciones

Presupuesto

Concepto	Horas	Coste (20 €/h)
Investigación y diseño	28	560 €
R01 - Segmentación	24	480 €
R02 - Microsegmentación	20	400 €
R03 - VPN	16	320 €
R04 - IDS	20	400 €
R05 - Zona crítica	16	320 €
R06 - Validación	20	400 €

Concepto	Horas	Coste (20 €/h)
Memoria	42	840 €
Defensa	12	240 €
Software (todo de código abierto)	-	0 €
Total	**198 h**	**3.960 €**

Tabla 11: Presupuesto

Git:

Todo el proyecto, configuraciones, documentación y evidencias, se ha gestionado con el sistema de control de versiones Git, alojado en un repositorio público en GitHub. El uso de control de versiones aporta trazabilidad, permite recuperar cualquier estado anterior y evidencia la evolución del trabajo a lo largo del tiempo, un requisito de la metodología del proyecto.

El fichero .gitignore excluye del control de versiones cualquier material sensible.

Repositorio: https://github.com/fran777fran/red-zero-trust-asir

README

El README.md es la puerta de entrada del repositorio: resume el objetivo del proyecto, la arquitectura (zonas y VLANs), los requisitos RFTP, las tecnologías empleadas con sus versiones, la estructura de carpetas y el resultado principal de la validación. Facilita que cualquier persona comprenda el proyecto y pueda reproducirlo.

DESARROLLO DE LA SOLUCIÓN

Despliegue e instalación

R01 Preparación del entorno de laboratorio

Objetivo: montar el entorno de emulación de red (GNS3) y desplegar el cortafuegos pfSense, base de la arquitectura Zero Trust.

Configuración realizada:

– Instalación de GNS3 (GUI) + GNS3 VM en VirtualBox (6 GB RAM, 2 vCPU, virtualización anidada activada).

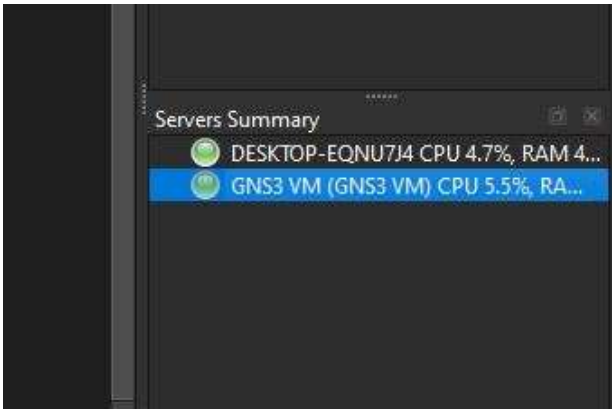


Ilustración 5: GNS3

– Añadida la plantilla de pfSense (appliance QEMU) e instalación de pfSense CE 2.9.0.

– Nodo pfSense con 6 interfaces (em0–em5): em0 = WAN conectada a un nodo NAT (salida a internet); em1 = LAN/troncal (192.168.1.1/24).

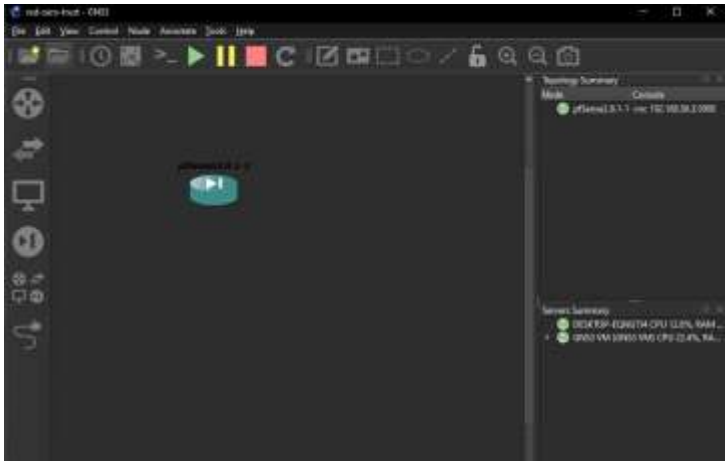


Ilustración 6: Pfsense

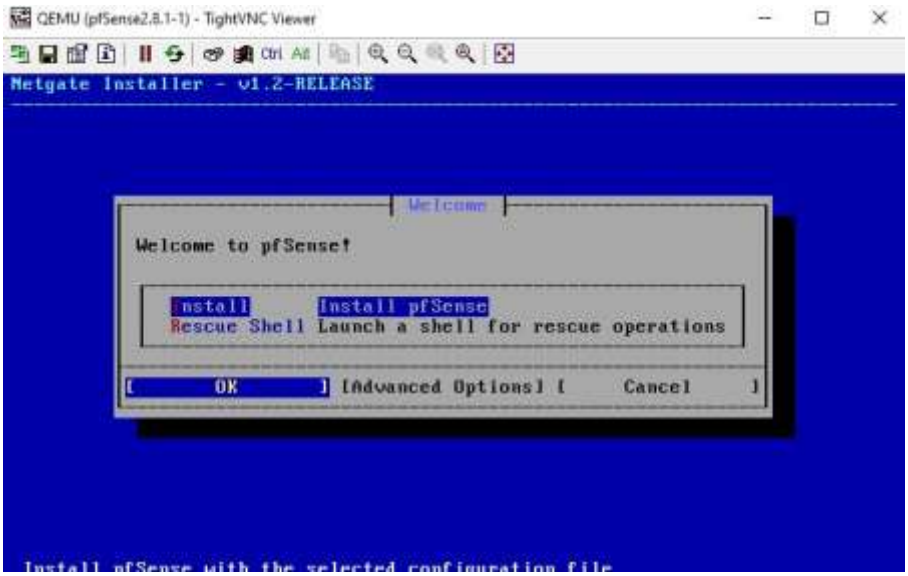


Ilustración 7: Instalación en pfsense

Incidencias controladas:

1. "DHCP server already exists" al habilitar el GNS3 VM (conflicto en el adaptador host-only de VirtualBox). Solución: eliminado el DHCP duplicado con VBoxManage dhcpserver remove para que GNS3 crease el suyo.

2. Sin aceleración KVM (/dev/kvm inexistente; sin virtualización anidada efectiva en el host). Solución: enable_kvm = false en gns3_server.conf; pfSense se ejecuta por emulación (más lento pero funcional).

3. El instalador de pfSense 2.9.0 es online y requería conexión con Netgate. Solución: WAN (em0) conectada al nodo NAT para dar internet; instalada la edición CE (sin suscripción Plus).

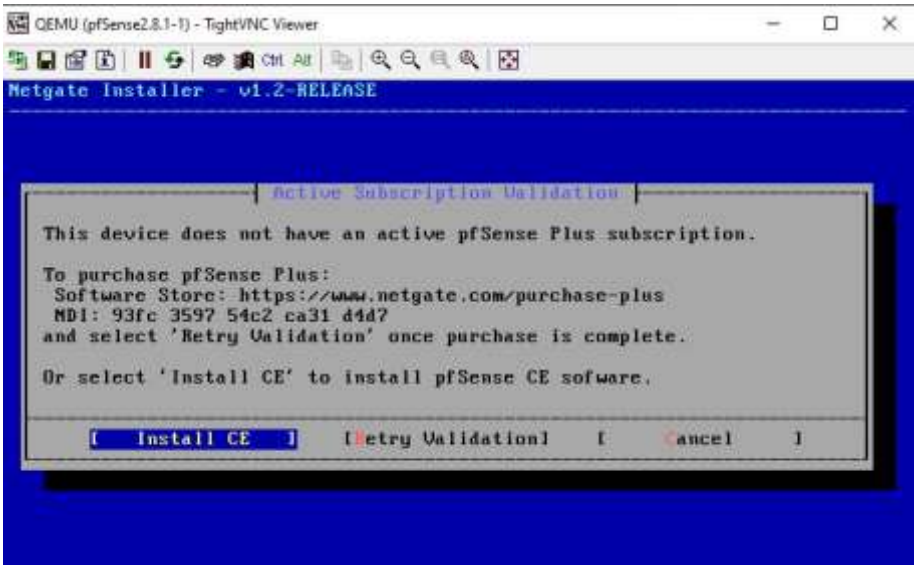


Ilustración 8: CE pfsense

Requisitos mínimos: VirtualBox + GNS3 3.x, GNS3 VM (6 GB / 2 vCPU), pfSense CE 2.9.0, ~8 GB de RAM libres.

R01F01T02 - Etiquetado 802.1Q en el conmutador

Objetivo: transportar las VLANs de las zonas de confianza hacia el cortafuegos por un enlace troncal 802.1Q.

Configuración realizada:

– Ethernet switch (Switch1) en GNS3.

– Puerto hacia pfSense (em1): tipo dot1q (troncal) - transporta todas las VLANs etiquetadas.

– Puerto hacia PC1 (VPCS): tipo access, VLAN 10 (zona Usuarios).

Evidencia: configuración de puertos del switch en GNS3

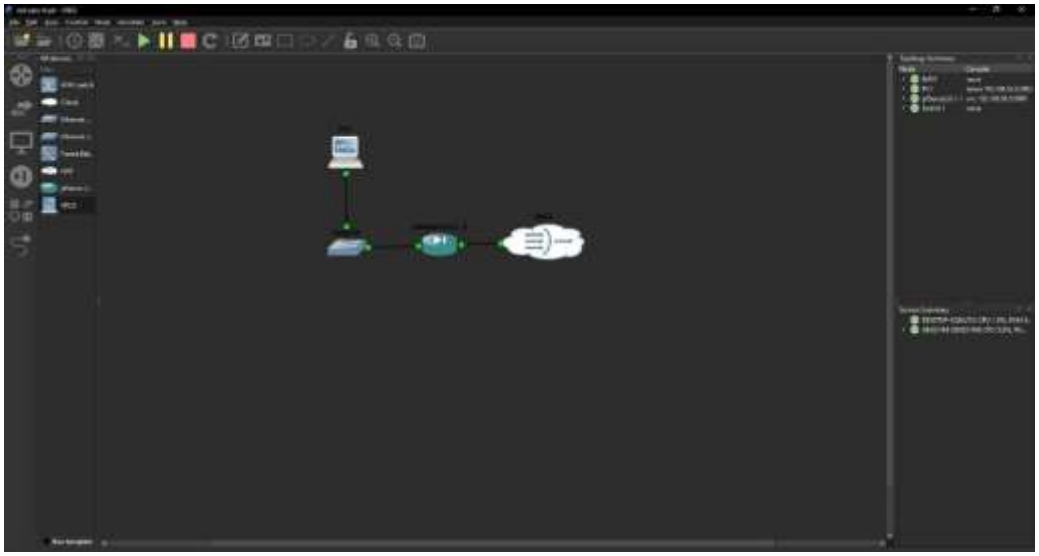


Ilustración 9: Proceso topología

Prueba (P): Se validará con el ping de PC1 a su gateway tras crear la VLAN 10 en pfSense (R01F01T01).

Incidencias: ninguna.

R01F01T01 Creación de VLANs y direccionamiento (VLAN 10)

Objetivo: crear la VLAN 10 (Usuarios) sobre em1 y asignarle direccionamiento 10.10.10.1/24.

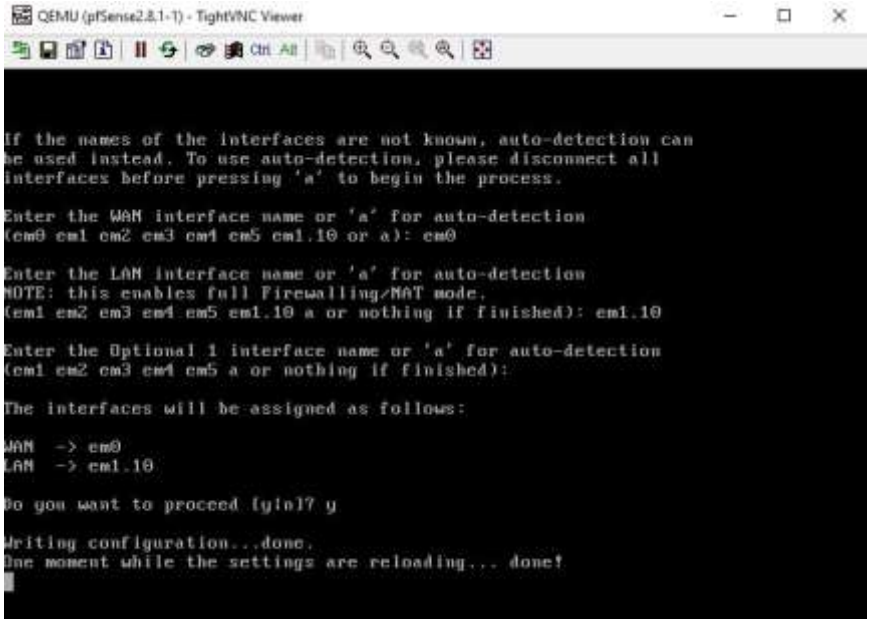


Ilustración 10: Creando Vlan10

Configuración realizada:

– pfSense (consola) opción 1 "Assign Interfaces": VLAN con parent em1, tag 10, asignada como LAN (em1.10).

– pfSense (consola) opción 2 "Set interface IP": em1.10 = 10.10.10.1/24; servidor DHCP habilitado (rango 10.10.10.100–200).

– Switch (GNS3): puerto a pfSense = dot1q VLAN 1 (troncal); puerto a PC1 = access VLAN 10.

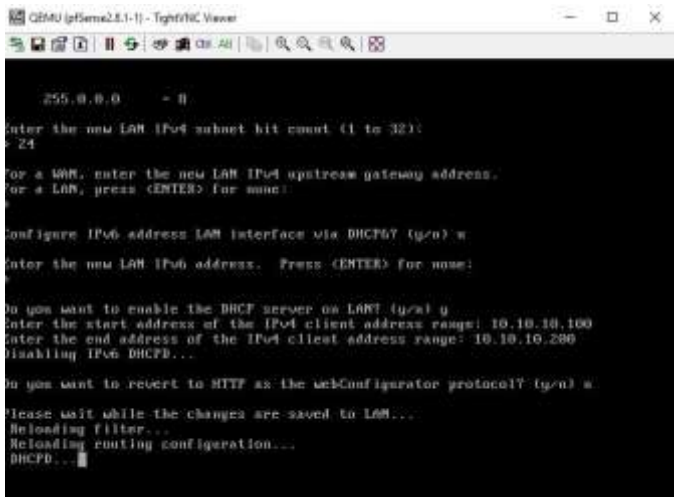


Ilustración 10: Configurando ip

Prueba (P): PC1 (VPCS) obtiene 10.10.10.100 por DHCP y hace ping a 10.10.10.1 > Resultado: correcto (~3–5 ms).

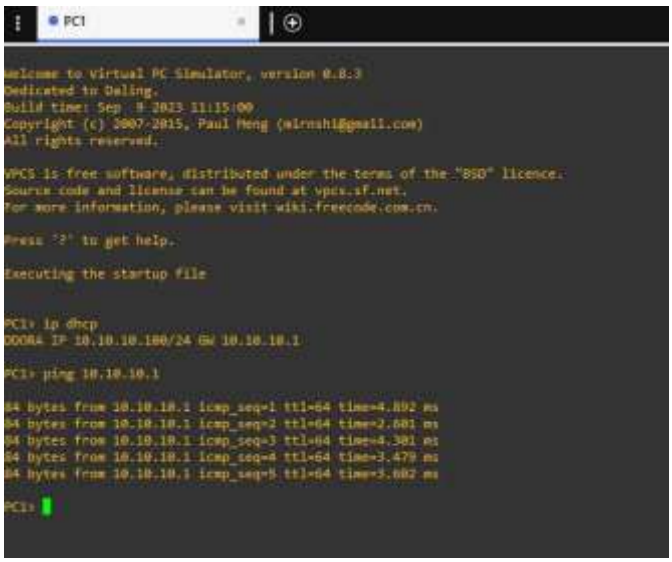


Ilustración 11: Ping funcional

Incidencias controladas:

Sin conectividad inicial: los puertos del switch estaban en access VLAN 1 por defecto y, al configurarlos, quedaron invertidos (dot1q/access en el puerto equivocado). Detectado con el tooltip del enlace (pfSense em1 = switch port 0; PC1 = switch port 1). Solución: port 0 = dot1q VLAN 1, port 1 = access VLAN 10.



Ilustración 12: Entra a pfsense

R01F01T01 (continuación) - Creación de las VLANs 20–50 (interfaz web)

- **Objetivo:** crear las zonas restantes (Servidores, DMZ, Gestión y Crítica) como VLANs sobre em1 y dotarlas de direccionamiento y DHCP, usando ya el webConfigurator.

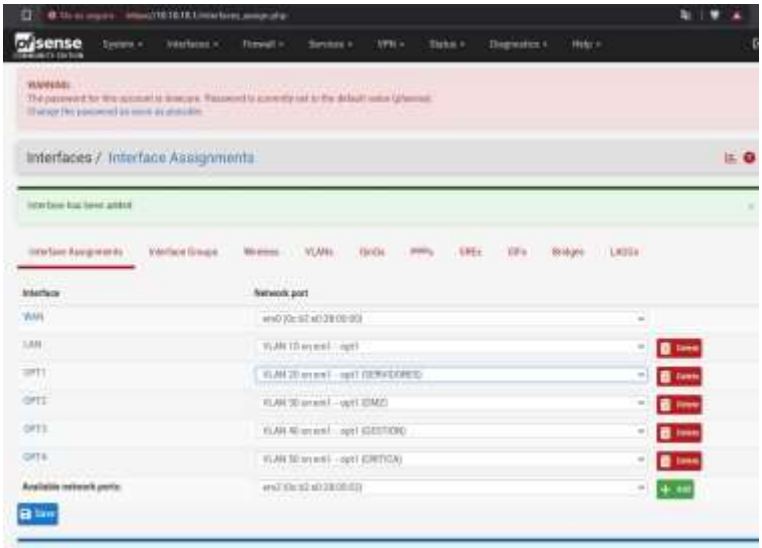


Ilustración 13: Redes en pfsense

- **Configuración realizada:**
  - *Interfaces > Assignments > VLANs*: creadas las VLAN 20 (SERVIDORES), 30 (DMZ), 40 (GESTION) y 50 (CRITICA), todas con interfaz padre em1.
  - *Interface Assignments*: asignadas como OPT1–OPT4 mediante "Available network ports > Add".
  - *Interfaces > OPTx*: cada interfaz habilitada, con IP estática (10.10.20.1, 10.10.30.1, 10.10.40.1 y 10.10.50.1, máscara /24, sin puerta de enlace) y su descripción de zona.

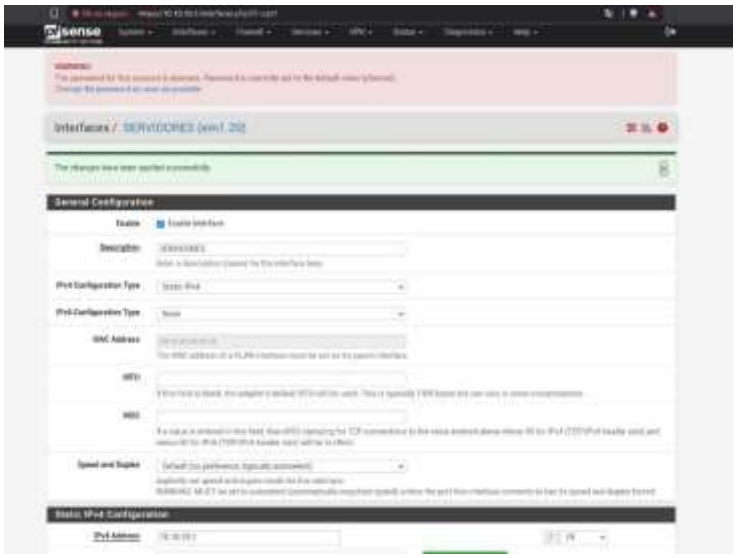


Ilustración 14: Ip en pfsense

  - *Services > DHCP Server*: servidor DHCP habilitado en cada zona (rango .100–.200).

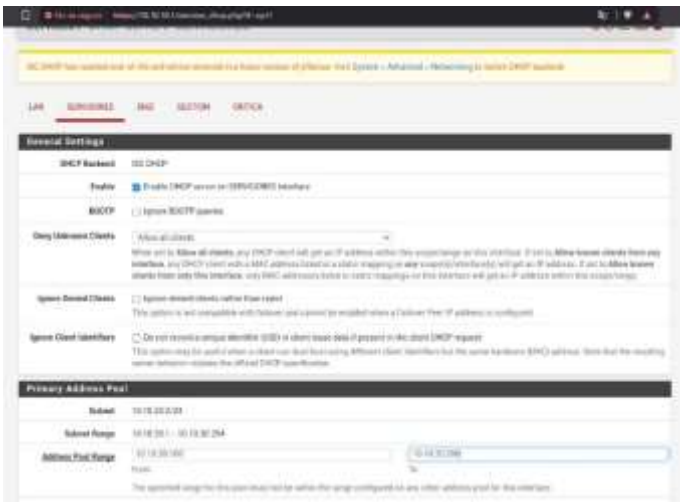


Ilustración 15: DHCP en pfsense

- **Evidencia:** Interface Assignments con WAN/LAN/OPT1–OPT4; configuración de cada interfaz; pestañas de DHCP
- **Resultado:** R01F01 completo. Las cinco zonas (VLANs 10–50) quedan creadas, direccionadas y con DHCP. Las interfaces OPT nacen **sin reglas (denegación por defecto)**, que constituye la línea base del modelo Zero Trust; la conectividad y el aislamiento entre zonas se validarán en R02.

R02 - Microsegmentación (denegación por defecto y mínimo privilegio)

- **Objetivo:** aplicar una política de denegación por defecto y permitir únicamente los flujos estrictamente necesarios entre zonas.
- **Fundamento (pfSense):** las reglas se evalúan en la **interfaz de origen**, de arriba abajo (gana la primera coincidencia), con una **denegación implícita** al final; todo lo no permitido queda bloqueado.
- **Reglas implementadas:**
    - *DMZ > Servidores (TCP 5432)*: el servicio de la DMZ accede a la base de datos/aplicación.

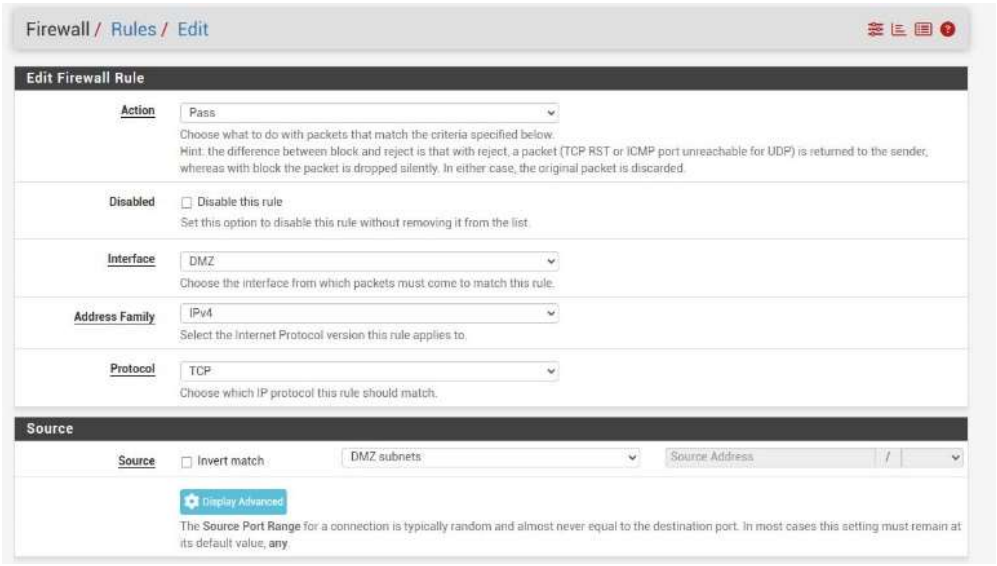


Ilustración 16: Regla DMZ

- *Gestión > cualquier destino (protocolo Any)*: zona de administración, con acceso a todas las zonas y al cortafuegos.



Ilustración 17: Regla Gestión

- *Usuarios > DMZ (TCP 443)*: los usuarios solo alcanzan el servicio web publicado.

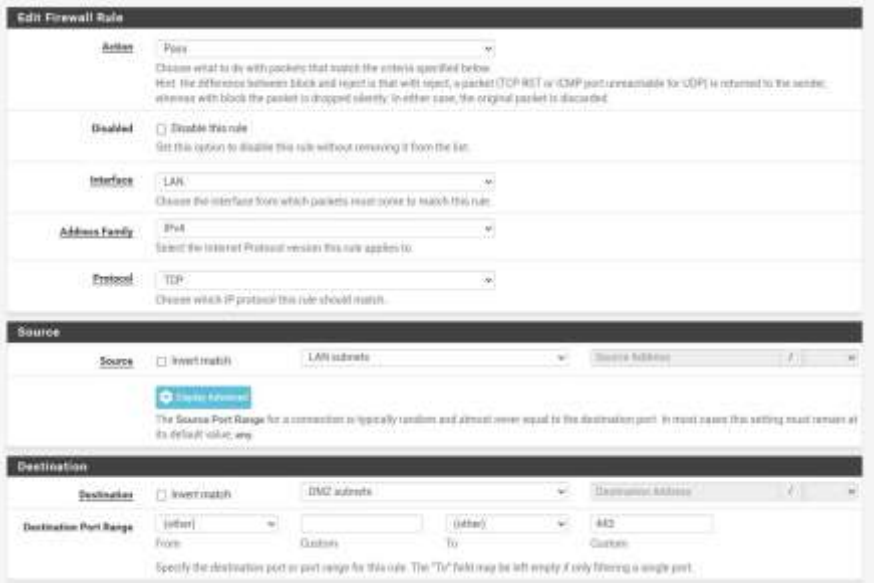


Ilustración 18: Regla usuarios nueva DMZ

- Se eliminaron las reglas por defecto "*allow LAN to any*" y se desactivó el *anti-lockout* de la LAN, de modo que rige la denegación por defecto.

- **Segregación de la gestión:** la estación de administración se trasladó de la VLAN 10 a la VLAN 40 (Gestión): se cambió el puerto del conmutador a la VLAN 40, se asignó al equipo la IP 10.10.40.2 y se añadió una ruta estática (10.10.0.0/16 vía 10.10.40.1). La administración pasa a https://10.10.40.1.

  Incidencias (controladas): (1) una regla se creó por error en la interfaz WAN y con el puerto 433, corregida a LAN y 443; (2) la regla de usuarios quedaba por debajo de la regla "*allow all*", que se eliminó para respetar el orden de evaluación; (3) el acceso de gestión exigía que la regla estuviera en protocolo **Any** (no solo TCP) y que el equipo de gestión tuviera **ruta** hacia las demás subredes.

R05 (Previa) - Contención de la zona crítica (prueba de aislamiento)

- **Objetivo:** comprobar que un host de otra zona no puede alcanzar la zona crítica y que solo la zona de Gestión puede hacerlo.
- **Prueba realizada:**
  - Desde un equipo de **Usuarios** (10.10.10.100): ping a **Crítica** (10.10.50.1) y a **Servidores** (10.10.20.1) > *tiempo de espera agotado* (bloqueado).
  - Desde el equipo de **Gestión** (10.10.40.2): ping a **Crítica** (10.10.50.1) > *respuesta correcta* (permitido).
- **Resultado:** el mismo destino (10.10.50.1) es **inaccesible desde Usuarios** y **accesible desde Gestión**, lo que demuestra la **contención del movimiento lateral** hacia la zona crítica y la **segregación del acceso de administración**, principios centrales del modelo Zero Trust.

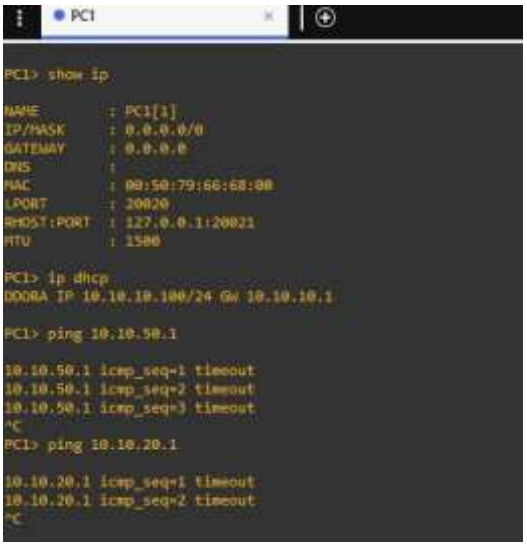


Ilustración 19: Comprobaciones pc1

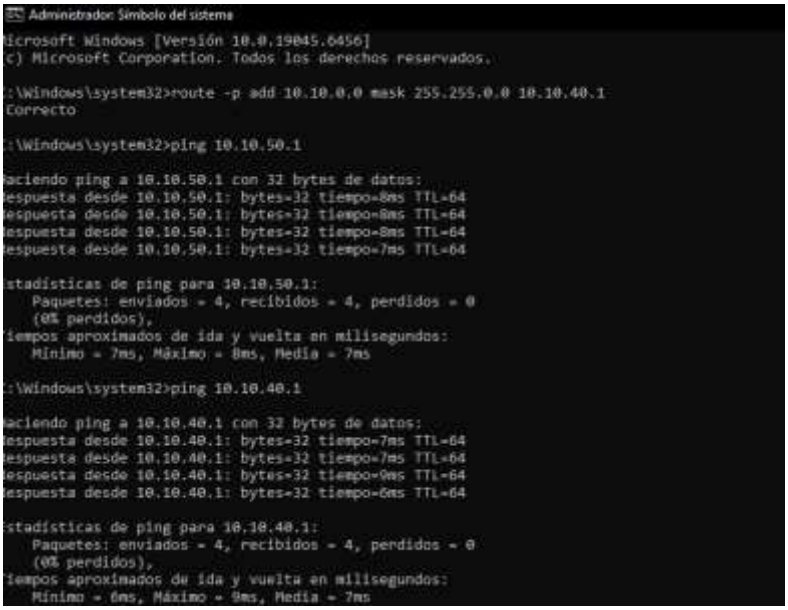


Ilustración 20: Comprobaciones 2

R03 Acceso remoto seguro mediante VPN (WireGuard): configuración del servidor

- **Objetivo:** proporcionar acceso remoto cifrado mediante una VPN WireGuard, sujeta también a las reglas del modelo Zero Trust (el usuario remoto no obtiene acceso total a la red).
- **Configuración realizada (lado servidor):**

Instalación del paquete **WireGuard** (System > Package Manager).

Creación del **túnel** (VPN > WireGuard > Tunnels): escucha en **UDP 51820**, red de túnel **10.10.90.0/24** (pfSense = 10.10.90.1) y generación del par de claves del servidor. WireGuard habilitado en *Settings*.



Ilustración 21: Instalación Wireguard

Asignación del túnel como **interfaz** (tun_wg0), con descripción **VPN**, tipo de IPv4 **None** e interfaz habilitada.

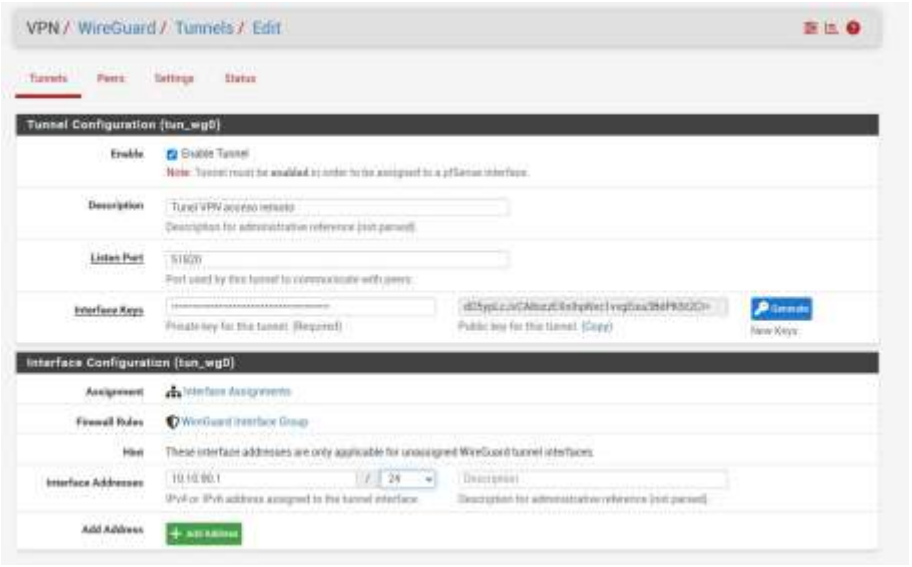


Ilustración 22: Creación de túnel

Regla en la WAN: permitir **UDP 51820** hacia la dirección WAN, de modo que el servicio WireGuard sea alcanzable desde el exterior.

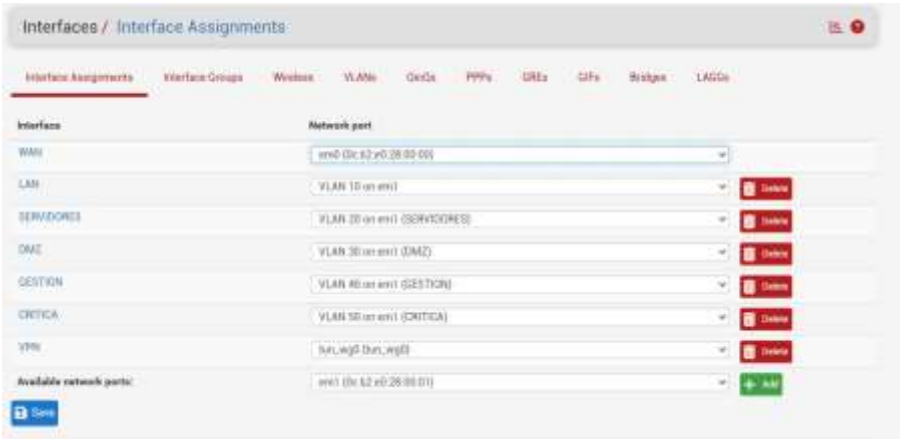


Ilustración 23: VPN



Ilustración 24: Wireguard en Lan

Desactivación de **"Block private networks"** en la WAN, dado que la "internet" del laboratorio es una red privada (192.168.42.0/24; WAN de pfSense = 192.168.42.88).

- **Incidencias (controladas):** (1) al asignar la interfaz se añadió por error la interfaz troncal em1, que se eliminó (em1 es el padre de las VLANs y no debe

asignarse); (2) la descripción "WIREGUARD" colisionaba con el grupo de interfaces homónimo creado por el paquete, por lo que se usó "VPN".

Cliente VPN y validación

- **Cliente (Kali):** se integró la máquina Kali en GNS3 en el **segmento WAN** (añadiendo un conmutador entre la WAN de pfSense y el NAT), simulando un usuario remoto en internet. En Kali se generó el par de claves (wg genkey/wg pubkey) y se configuró el túnel (/etc/wireguard/wg0.conf) con: su clave privada, dirección 10.10.90.2/24, clave pública del servidor, *endpoint* 192.168.42.88:51820 y AllowedIPs = 10.10.0.0/16.

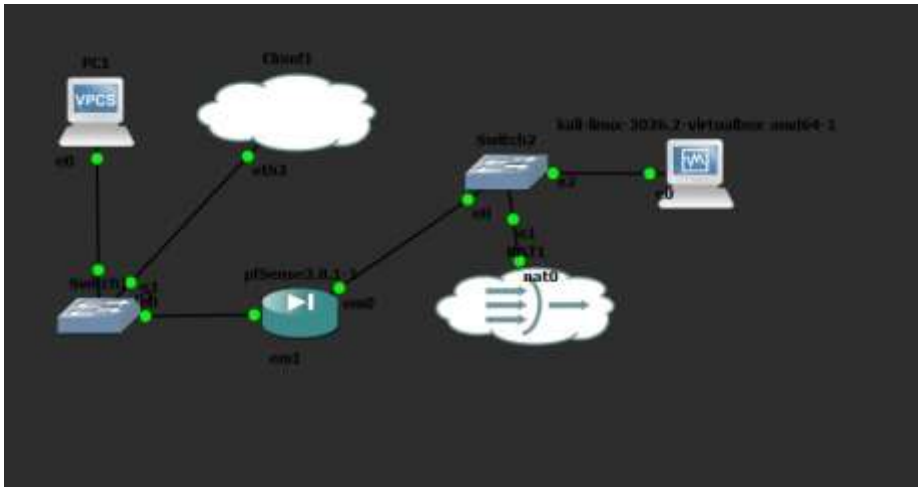


Ilustración 25: Añadido Kali

- **Peer en pfSense:** se dio de alta el *peer* "Cliente Kali" con la clave pública del cliente y *Allowed IPs* 10.10.90.2/32.

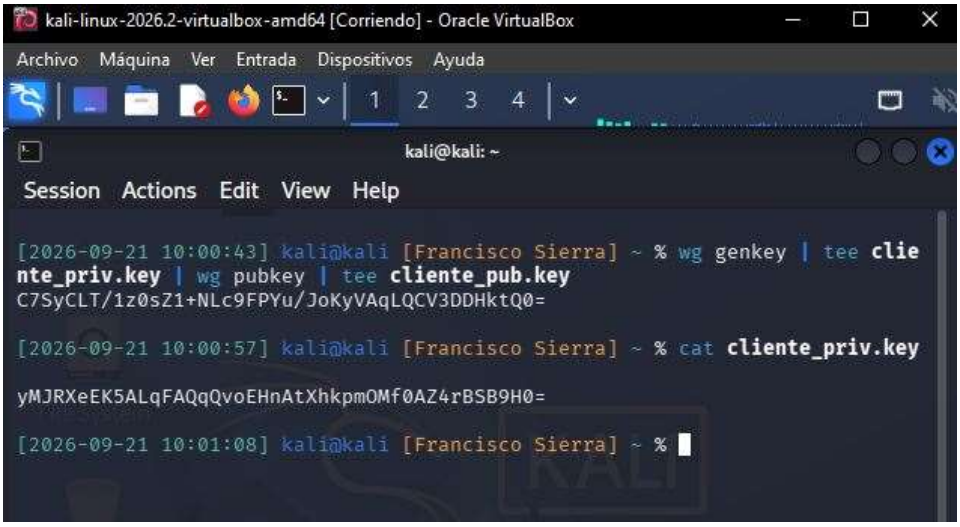


Ilustración 26: Claves Kali

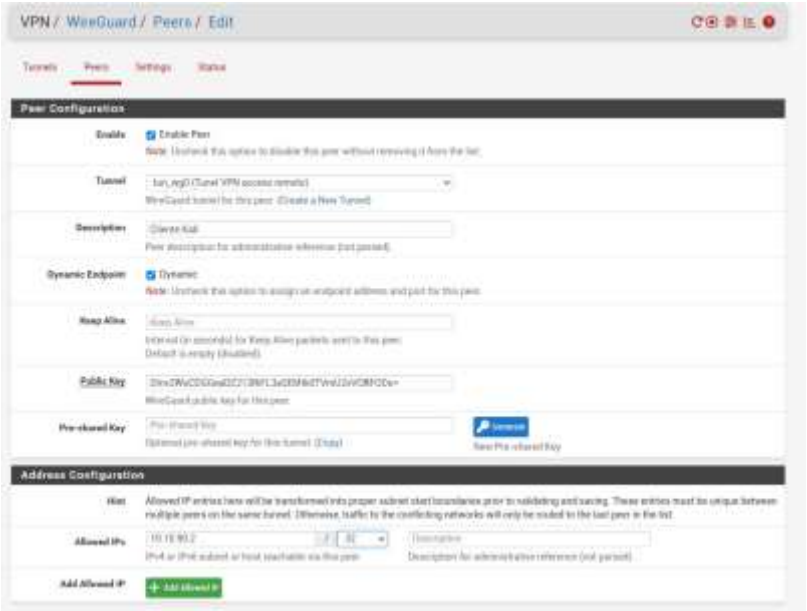


Ilustración 27: Wireguard Peer

- **Regla de mínimo privilegio (interfaz VPN):** permitir 10.10.90.0/24 > **Servidores**; el resto (incluida la zona crítica) queda bloqueado por la denegación por defecto.

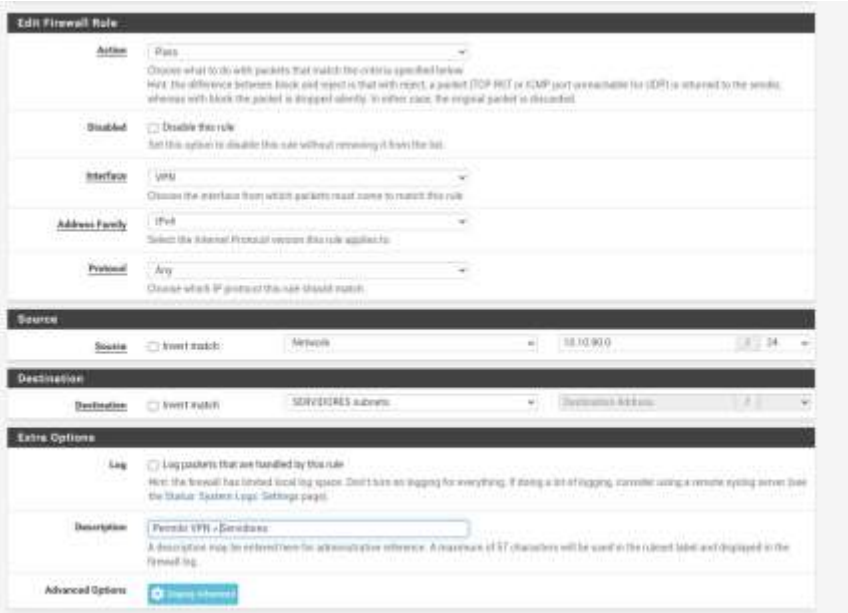


Ilustración 28: Mínimo privilegio

- **Incidencia (controlada):** el túnel establecía *handshake* pero no había respuesta. La causa: en esta versión del paquete, la **dirección del túnel se configura en la interfaz asignada** (no en el túnel) y estaba en *None*, por lo que faltaba la ruta 10.10.90.0/24 en pfSense y el tráfico de retorno se perdía. Solución: asignar **IPv4 estática 10.10.90.1/24** a la interfaz VPN, con lo que aparece la ruta y el retorno funciona.

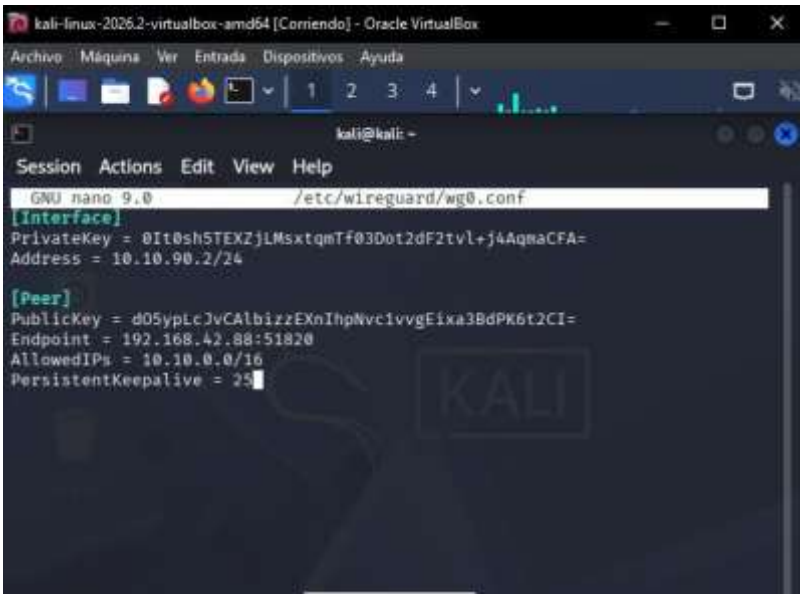


Ilustración 29: wgo conf

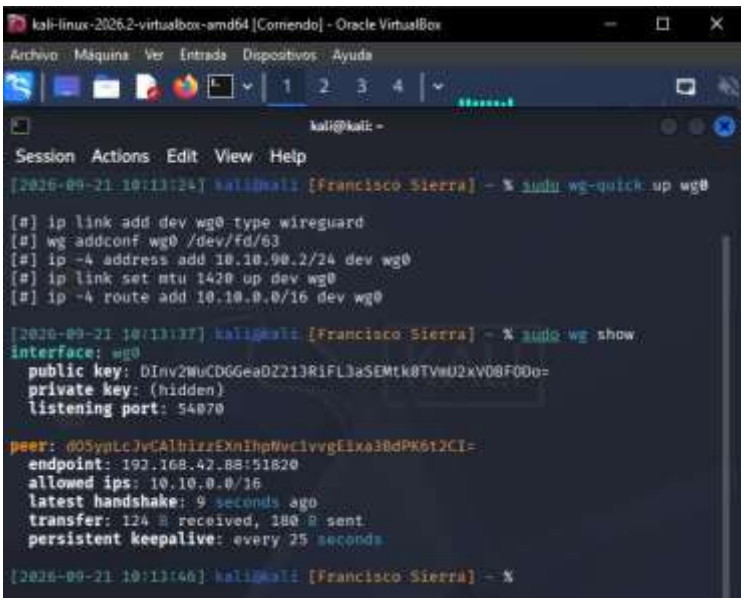


Ilustración 30: Túnel realizado

- **Prueba (P):** con el túnel activo, desde el cliente remoto: ping a **Servidores (10.10.20.1), responde**; ping a **Crítica (10.10.50.1), bloqueado**.
- **Resultado:** acceso remoto por VPN cifrada operativo y **sujeto al modelo Zero Trust**: el usuario remoto alcanza solo el segmento autorizado, nunca la zona crítica.

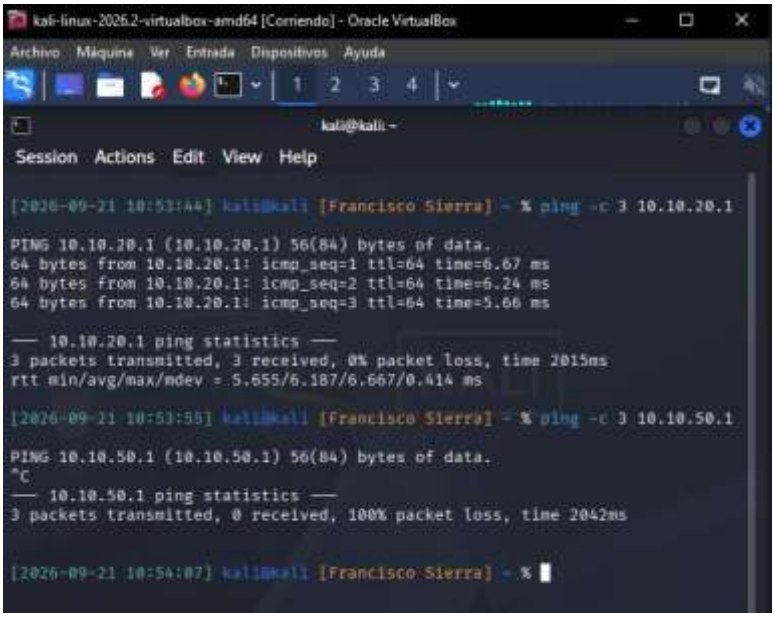


Ilustración 31: Pings finales correctos

R04 Sistema de detección de intrusiones (IDS)

Objetivo: dotar a la arquitectura de una capa de detección que inspeccione el tráfico dirigido a la zona de Servidores y genere alertas ante actividades de reconocimiento (escaneo de puertos), en coherencia con el principio Zero Trust de monitorización continua y asunción de compromiso ("assume breach").

Función técnica (F): desplegar el IDS Suricata como paquete integrado en el cortafuegos pfSense, asociarlo a la interfaz de la VLAN 20 (Servidores) y definir un conjunto de reglas -de repositorio y propias- capaz de identificar un barrido de puertos procedente de la red de acceso remoto (VPN).

Configuración realizada:

– Instalación del paquete Suricata desde el gestor de paquetes de pfSense (System > Package Manager).



Ilustración 32: Suricata instalado

– Creación de una instancia de Suricata ("IDS-Servidores") sobre la interfaz SERVIDORES (em1.20), en modo de detección y registro.

– Descarga y activación del conjunto de reglas Emerging Threats Open (ET Open), que incorpora las categorías de escaneo y reconocimiento.

– Definición de reglas propias (custom.rules) para adaptar la detección al modelo de la maqueta:

· Regla de verificación (SID 1000010): alerta ante cualquier tráfico ICMP; empleada para confirmar que el motor inspecciona el segmento y carga correctamente las reglas propias.

· Regla de detección de escaneo (SID 1000001): alerta ante segmentos TCP con el flag SYN activo procedentes de la red VPN (10.10.90.0/24) y dirigidos a la red de Servidores (10.10.20.0/24), con un umbral de 5 intentos en 60 segundos por origen. La expresión "flags:S,12" reconoce el SYN ignorando los bits reservados de la cabecera TCP, lo que hace la detección más robusta.



Ilustración 33: Custom rules

Prueba (P04):

Con el túnel WireGuard establecido, desde el equipo atacante (Kali, cliente VPN con dirección 10.10.90.2):

1. Ping hacia el host de Servidores (10.10.20.100): Suricata registra la alerta "ICMP detectado (test IDS)" (SID 1000010), lo que confirma que el IDS inspecciona el tráfico procedente de la VPN.

2. Escaneo de puertos ("nmap -sS -p 1-200 10.10.20.100"): Suricata genera la alerta "Escaneo de puertos SYN desde VPN hacia Servidores" (SID 1000001), clasificada como "Attempted Information Leak" y prioridad 2, con origen 10.10.90.2 y destino 10.10.20.100.

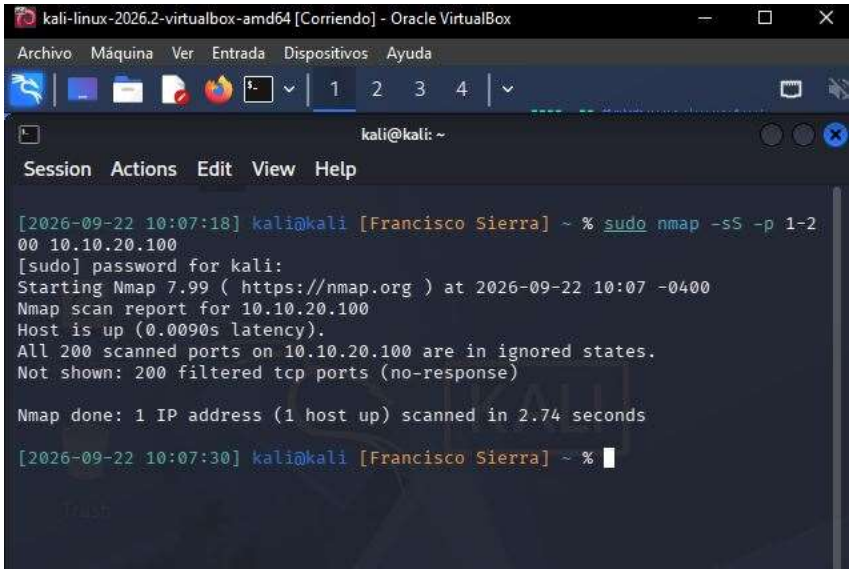


Ilustración 34: Escaneos Kali

Resultado: detección de reconocimiento correcta. El IDS identifica y registra el intento de escaneo, aportando la visibilidad necesaria para reaccionar antes de que el reconocimiento derive en fases posteriores del ataque.



Ilustración 35: Alerta detectada

Incidencias controladas:

1. Las reglas ET SCAN del repositorio no se activaban ante un escaneo interno: al abarcar HOME_NET todas las redes privadas, dichas firmas -orientadas al sentido exterior>interior ($EXTERNAL_NET > $HOME_NET)- no coincidían con

un origen también interno. Solución: redactar una regla propia orientada al flujo concreto VPN > Servidores.

2. Ruido del decodificador "TCPv4 invalid checksum" derivado del descargado por hardware (offloading) propio del entorno de emulación. Solución: desactivar las tres opciones de offloading en System > Advanced > Networking y reiniciar el cortafuegos.

3. Fallo en la descarga de reglas ("Could not resolve host") por resolución DNS. Solución: fijar servidores DNS (8.8.8.8 / 1.1.1.1), desactivar "DNS Server Override" y habilitar el modo de reenvío del DNS Resolver.

4. Ausencia inicial de detección del escaneo: el túnel WireGuard estaba inactivo tras reiniciar la topología, por lo que no circulaba tráfico de la VPN (el filtro por origen 10.10.90.2 no devolvía resultados). Solución: levantar el túnel en el cliente ("wg-quick up wg0") y confirmar con la alerta ICMP.

5. La primera versión de la regla (coincidencia estricta "flags:S" y umbral de 15 intentos en 10 segundos) no se activaba. Solución: emplear "flags:S,12" y rebajar el umbral a 5 intentos en 60 segundos (revisión 2 de la regla).

Resultado del requisito: R04 completado. La arquitectura incorpora una capa de detección operativa que inspecciona el tráfico hacia la zona de Servidores y registra los intentos de reconocimiento procedentes del acceso remoto, aportando la visibilidad y la trazabilidad que exige el modelo Zero Trust.

R05 Contención de la zona crítica

Objetivo: verificar que un equipo situado en una zona de menor confianza NO puede alcanzar la zona crítica (VLAN 50) y que únicamente la zona de Gestión dispone de acceso autorizado. Es la materialización del principio Zero Trust de contención y limitación del movimiento lateral: aun asumiendo el compromiso de un equipo interno, el atacante no debe poder progresar hacia los activos más sensibles.

Función técnica (F): apoyándose en la microsegmentación del R02 (denegación por defecto), comprobar que ninguna zona posee reglas que habiliten el tráfico hacia la

red crítica 10.10.50.0/24, salvo la administración, y validarlo empíricamente mediante pruebas de conectividad.

Configuración realizada:

– La interfaz de la VLAN 50 (Crítica) nace sin reglas de entrada permitidas > rige la denegación implícita.

– Ninguna zona (Usuarios, Servidores, DMZ) tiene reglas que autoricen el acceso a 10.10.50.0/24.

– El acceso de administración se habilita mediante la regla "GESTION > any" (interfaz Gestión), que permite a la zona de Gestión alcanzar el resto de segmentos, incluida la zona crítica, para tareas de operación y mantenimiento.

Prueba (P05):

1. Desde PC1 (zona Usuarios, 10.10.10.100): ping a 10.10.50.1 (Crítica) y a 10.10.20.1 (Servidores) > tiempo de espera agotado = tráfico BLOQUEADO.

2. Desde el equipo de Gestión (10.10.40.2): ping a 10.10.50.1 (Crítica) > respuesta correcta = tráfico PERMITIDO.

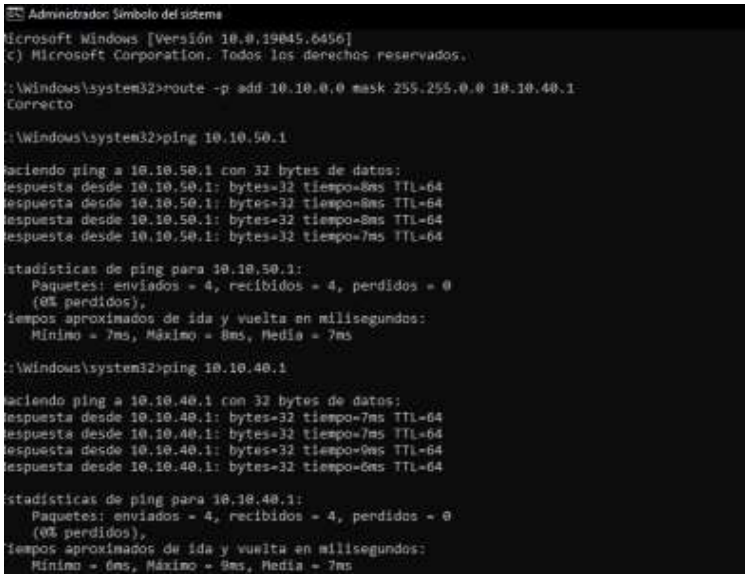


Ilustración 36: Tráfico

Resultado: un mismo destino (10.10.50.1) queda bloqueado cuando el origen es la zona de Usuarios y permitido cuando el origen es la zona de Gestión. El contraste

demuestra de forma directa la contención de la zona crítica (ausencia de movimiento lateral hacia los activos sensibles) y el acceso de administración segregado, coherentes con el modelo Zero Trust.

Incidencias: ninguna propia. Las incidencias de conectividad relacionadas (la regla de Gestión debía ser de protocolo "Any" y el equipo de gestión necesitaba una ruta estática hacia el resto de subredes) se resolvieron y quedan documentadas en el R02.

Validación adicional: la contención se somete a una prueba más exigente en el R06, donde un equipo atacante realiza un escaneo activo de todas las zonas y se comprueba que solo alcanza los servicios autorizados, permaneciendo la zona crítica inaccesible.

Resultado del requisito: R05 completado. La zona crítica queda aislada frente a las zonas de menor confianza y accesible únicamente desde la administración, conteniendo el movimiento lateral conforme al modelo Zero Trust.

R06 Validación y comparativa (red segmentada frente a red plana)

Objetivo: validar de forma empírica que la arquitectura segmentada Zero Trust reduce la superficie de ataque y contiene el reconocimiento de un atacante, comparándola con el comportamiento de una red plana equivalente (sin segmentación).

Función técnica (F): ejecutar, desde una posición de atacante, un reconocimiento de red (descubrimiento de hosts y escaneo de puertos con nmap) bajo dos políticas de cortafuegos -segmentada y plana- y comparar los resultados.

Metodología: experimento controlado. Se mantiene fijo el punto de ataque (Kali como cliente VPN, dirección 10.10.90.2, que representa el modelo de amenaza de "credenciales VPN comprometidas") y el conjunto de objetivos (una dirección representativa por zona), y se varía ÚNICAMENTE la política del cortafuegos. Así, cualquier diferencia observada es atribuible a la segmentación.

Escenario A - Red segmentada (estado real Zero Trust):

– Política activa: única regla de paso "VPN > Servidores" más la denegación implícita. Se verificó que las pestañas Floating y del grupo WireGuard estaban vacías, confirmando que el bloqueo es por diseño y no fruto de una regla residual.

– Descubrimiento de hosts (nmap -sn) sobre una IP por zona: solo se descubren los hosts de Servidores (2 de 6).

– Escaneo de puertos a Servidores (zona autorizada): host alcanzable y enumerable.

– Escaneo de puertos a Crítica: host inalcanzable (sin respuesta) = tráfico bloqueado.



Ilustración 37: Nmap 2



Ilustración 38: Nmap 3



Ilustración 39: Nmap 3

Escenario B - Red plana (simulada):

– Política activa: regla temporal de paso total (10.10.90.0/24 > cualquier destino) en la interfaz VPN, que emula la ausencia de segmentación. La regla se eliminó inmediatamente después de la prueba para restaurar el modelo Zero Trust.

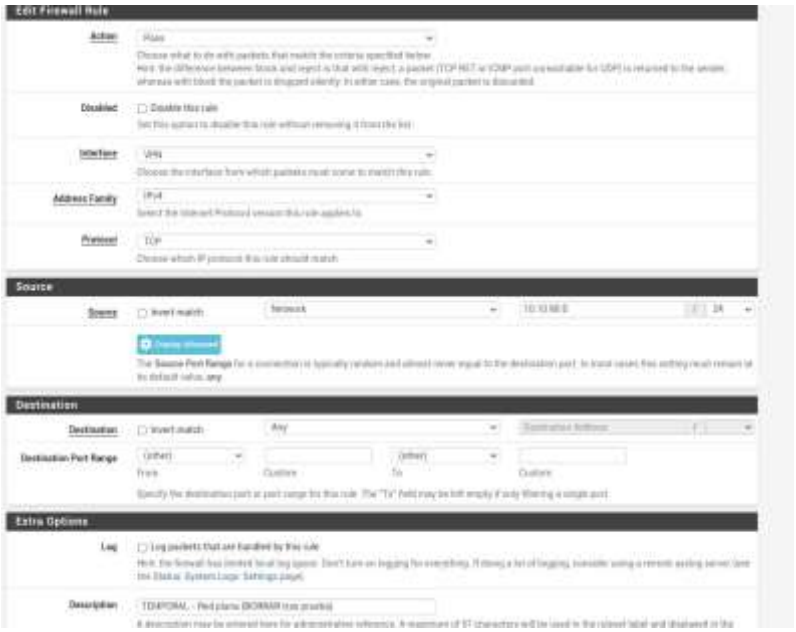


Ilustración 40: Regla temporal

– Descubrimiento de hosts (nmap -sn): se descubren TODAS las zonas (6 de 6).

– Escaneo de puertos a Crítica y a Gestión: hosts alcanzables, con servicios del propio cortafuegos expuestos (53/tcp DNS y 80/tcp HTTP).



Ilustración 41: Nmap con Regla temporal

Resultados (comparativa):

Objetivo (zona)	**A · Red segmentada (Zero Trust)**	**B · Red plana**
Servidores 10.10.20.1 / .100 (autorizada)	Alcanzable	Alcanzable
Usuarios 10.10.10.1	Bloqueado	Alcanzable
DMZ 10.10.30.1	Bloqueado	Alcanzable
Gestión 10.10.40.1	Bloqueado	Alcanzable (53/80)
Crítica 10.10.50.1	Bloqueado	Alcanzable (53/80)
Hosts descubiertos (nmap -sn)	**2 de 6**	**6 de 6**

Tabla 12: Alcance del reconocimiento desde el atacante según la política de red.

Prueba (P06): ejecución de los mismos comandos nmap en ambos escenarios desde Kali (10.10.90.2). Resultado: en la red segmentada el atacante solo descubre y alcanza la zona autorizada (Servidores), mientras que en la red plana alcanza la totalidad de la infraestructura, incluida la zona crítica y los servicios de gestión del cortafuegos. Como efecto colateral, el escaneo del Escenario A vuelve a activar la alerta del IDS (R06 se apoya así en el R04, evidenciando detección y contención simultáneas).

Conclusión razonada: la segmentación Zero Trust reduce la superficie de reconocimiento de 6/6 a 2/6 zonas y confina al atacante a la única zona autorizada, conteniendo el movimiento lateral. En la red plana, un único punto de acceso comprometido (credenciales VPN) expone toda la infraestructura, incluidos los activos críticos y el plano de gestión. La comparativa demuestra, con datos reproducibles, el valor de la microsegmentación y del principio de mínimo privilegio.

TRABAJOS FUTUROS

La arquitectura desarrollada constituye una base sólida y funcional que valida el modelo Zero Trust en laboratorio. A partir de ella se identifican varias líneas de evolución que amplían su alcance y la proyectan hacia un despliegue en un entorno de producción real, ordenadas de menor a mayor envergadura.

Ampliación a un entorno de producción:

– Trasladar el modelo, ya validado, a un despliegue piloto con servicios de producción reales sobre cada zona: aplicaciones web en la DMZ y bases de datos y servicios internos en la zona de Servidores.

– Extender la política de mínimo privilegio a los flujos propios de un entorno productivo: políticas de salida a internet diferenciadas por zona y publicación controlada de servicios hacia el exterior.

Detección y respuesta:

– Evolucionar el IDS a modo IPS (prevención en línea) y centralizar los registros en un SIEM o servidor syslog para la correlación de eventos y la respuesta ante incidentes.

– Ampliar el conjunto de firmas propias a otras técnicas de ataque (exfiltración de datos, fuerza bruta, movimiento lateral).

Autenticación y control de acceso:

– Reforzar la autenticación del acceso remoto mediante doble factor y certificados de cliente.

– Incorporar IPsec/IKEv2 como alternativa estandarizada en entornos gubernamentales, conforme a la comparativa realizada en el marco teórico.

– Añadir control de acceso a la red por puerto (802.1X/NAC) para autenticar los dispositivos antes de asignarles su zona.

Operación, robustez y escalado:

– Automatizar el despliegue y la configuración mediante infraestructura como código (p. ej., Ansible) para garantizar la reproducibilidad y el control de cambios.

– Introducir alta disponibilidad del cortafuegos (CARP) para eliminar el punto único de fallo.

– Evolucionar de la segmentación basada en red a la microsegmentación basada en identidad (modelos ZTNA/SASE), aplicando el principio "nunca confiar, siempre verificar" a nivel de aplicación y usuario, y trasladar la solución a un entorno físico o de nube.

CONCLUSIONES

El proyecto ha cumplido su objetivo general: diseñar, desplegar y validar en un laboratorio virtualizado una arquitectura de red corporativa segmentada según el modelo Zero Trust (NIST SP 800-207) orientada a la protección de infraestructuras críticas, demostrando que reduce la superficie de ataque y contiene el movimiento lateral frente a una red plana tradicional.

Se han alcanzado los seis requisitos planteados en los objetivos (RFTP): la segmentación en zonas de confianza mediante VLANs sobre un enlace troncal 802.1Q (R01); la microsegmentación con denegación por defecto y reglas de mínimo privilegio en el cortafuegos como punto de aplicación de políticas (R02); el acceso remoto cifrado por VPN WireGuard, acotado a un único segmento (R03); la detección de intrusiones con Suricata, capaz de identificar y registrar el reconocimiento (R04); la contención de la zona crítica, inaccesible desde las zonas de menor confianza y reservada a la administración (R05); y la validación comparativa mediante escaneos con nmap (R06).

El resultado más significativo es la evidencia cuantitativa de la comparativa: en la red plana un único punto de acceso comprometido descubre y alcanza la totalidad de las zonas (6 de 6), incluidos los activos críticos y el plano de gestión del propio cortafuegos, mientras que con segmentación Zero Trust el mismo atacante queda confinado a la única zona autorizada (2 de 6 hosts descubiertos), sin capacidad de progresar hacia la zona crítica. La detección del escaneo por parte del IDS, activada durante esa misma prueba, confirma además que contención y visibilidad operan de forma simultánea.

Desde el punto de vista técnico, el proyecto demuestra que el modelo Zero Trust puede implementarse de forma realista y reproducible con herramientas de código abierto (GNS3, pfSense, WireGuard, Suricata, nmap) y con recursos de hardware modestos, lo que lo hace viable para organizaciones con presupuesto limitado — pymes y organismos públicos-y no solo para grandes infraestructuras con soluciones comerciales.

Lecciones aprendidas:

– La eficacia de la microsegmentación depende del rigor en el orden de evaluación de las reglas: una regla permisiva mal ubicada anula el mínimo privilegio.

– La validación de seguridad debe partir siempre de un estado limpio: al ser el cortafuegos de inspección de estado, los estados residuales de sesiones anteriores pueden dar falsos positivos de conectividad.

– El entorno de emulación introduce artefactos (sumas de comprobación inválidas por el offloading, respuesta a todos los puertos de los nodos VPCS) que hay que identificar para no confundirlos con resultados reales.

– Una regla de detección genérica no basta: fue necesario adaptar la firma al flujo concreto (origen/destino y umbral) para detectar el reconocimiento interno.

Por último, el trabajo integra y aplica de forma transversal las competencias del ciclo de Administración de Sistemas Informáticos en Red (planificación y administración de redes, seguridad y alta disponibilidad, y servicios de red) sobre un caso de uso de ciberseguridad y protección de infraestructuras críticas, alineado con el ámbito profesional de la defensa y la seguridad nacional al que se orienta el proyecto.

REFERENCIAS

Aplicado en los antecedentes para documentar el origen del concepto Zero Trust.

Kindervag, J. (2010). No More Chewy Centers: Introducing the Zero Trust Model of Information Security. Forrester Research. Recuperado de https://media.paloaltonetworks.com/documents/Forrester-No-More-Chewy-Centers.pdf

Aplicado en el marco teórico para definir el modelo Zero Trust y sus componentes lógicos (PEP, PDP, PE).

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. Recuperado de https://doi.org/10.6028/NIST.SP.800-207

Aplicado en la motivación para aportar el dato del 32 % de brechas con ransomware o extorsión.

Verizon. (2024). 2024 Data Breach Investigations Report (DBIR). Verizon Business. Recuperado de https://www.verizon.com/business/resources/reports/dbir/

Aplicado en los antecedentes para respaldar el contexto europeo de amenazas (ransomware como amenaza principal).

European Union Agency for Cybersecurity. (2024). ENISA Threat Landscape 2024. ENISA. Recuperado de https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024

Aplicado en la motivación para tipificar técnicamente el movimiento lateral.

MITRE. (s. f.). Lateral Movement, Tactic TA0008 - Enterprise. MITRE ATT&CK. Recuperado de https://attack.mitre.org/tactics/TA0008/

Aplicado en los antecedentes para justificar la adopción institucional de Zero Trust en la Administración estadounidense.

The White House. (2021). Executive Order 14028: Improving the Nation's Cybersecurity. Federal Register. Recuperado de https://www.federalregister.gov/documents/2021/05/17/2021-10460/improving-the-nations-cybersecurity

Aplicado en los antecedentes como ejemplo de estrategia federal de Zero Trust.

Office of Management and Budget. (2022). Moving the U.S. Government Toward Zero Trust Cybersecurity Principles (Memorandum M-22-09). Recuperado de https://zerotrust.cyber.gov/downloads/M-22-09%20Federal%20Zero%20Trust%20Strategy.pdf

Aplicado en el marco normativo para enlazar Zero Trust con el Esquema Nacional de Seguridad español.

Jefatura del Estado. (2022). Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. Boletín Oficial del Estado, núm. 106. Recuperado de https://www.boe.es/eli/es/rd/2022/05/03/311/con